Bumblebee - Gold Cabin

Incident analysis report - Bumblebee loader intrusion ending in Conti ransomware

Victim organization	CompliantSecure (Active Directory domain ad.compliantsecure.store)
Affected assets	MAIL01 mail server (DMZ), IT01 workstation (10.10.11.110), DC01 domain controller (10.10.11.156), FILESERVER01 file server (10.10.11.18), Support01 workstation
Threat actor	Gold Cabin, using the Bumblebee loader as the first stage
Initial access	Phishing email sent through a spoofed-sender mail service; malicious ISO image downloaded through the company webmail
Evidence analyzed	Centralized Elastic stack logs: Sysmon, Windows Security, Windows Filtering Platform, System and mail server logs
Tools used	Kibana Discover, VirusTotal
Overall result	Confirmed compromise: domain administrator credentials stolen, persistence on the domain controller, documents staged for exfiltration and Conti ransomware deployed from a network share

1. Executive Summary

CompliantSecure runs an Active Directory environment with a mail server in the DMZ, user workstations, a file server and a domain controller. The company was targeted by the threat actor Gold Cabin, which used the Bumblebee loader as the first stage of an intrusion. From my analyst workstation I searched the logs collected from the affected hosts to establish what the attacker did and how far they got.

The logs show the full attack chain. A phishing email sent through a spoofed-sender service led to an ISO image being downloaded from webmail. A shortcut inside the image ran a malicious DLL through **rundll32.exe**, which started a beacon, injected code into a legitimate Windows process and began calling out to external command and control servers. The attacker then enumerated the domain, dumped LSASS with ProcDump, used stolen domain administrator credentials to reach the domain controller over SMB, installed a service and a rogue administrator account, deployed AnyDesk, connected over RDP, collected documents from the file server, opened the webmail from the support workstation and finally launched ransomware from a network share on several hosts. The whole environment must be treated as compromised.

2. Scope and Evidence

This report covers the incident of 1 December 2024. All timestamps are UTC and come from the log records themselves. The evidence is the set of logs ingested into the company Elastic stack and searched through Kibana Discover: Sysmon (event IDs 1, 3, 8, 10, 11 and 15), Windows Security (4624, 4648, 4720, 4776, 5156 and 5158), the System log (7045) and the Postfix logs of the mail server. VirusTotal was used to check the reputation of the sender domain and of the ransomware hash. All findings below come from this evidence.

Host	Role	Address
MAIL01	Mail server in the DMZ, webmail interface	10.10.3.108 (public 35.158.110.49)
IT01	IT workstation, first host compromised	10.10.11.110
DC01	Domain controller	10.10.11.156

Host	Role	Address
FILESERVER01	File server holding the shared folders	10.10.11.18
Support01	Support workstation	-

3. Background: How This Intrusion Pattern Works

Knowing the pattern defines what to look for in the logs. Bumblebee-style intrusions usually start with a phishing email that delivers a container file such as an ISO image. Container files are favored because many mail filters do not inspect their contents, and the files inside do not always receive the same security warnings as a direct download. Inside the image sits a shortcut (.lnk) that looks like a document and a DLL. Opening the shortcut runs the DLL through rundll32.exe, which gives the attacker a beacon. From there the operator injects into a legitimate process, performs discovery, steals credentials, moves laterally with them, installs persistence and, in this case, ends with ransomware. I used this sequence as the map for the investigation.

4. Investigation Phases

Phase 1 - Initial Access Through a Phishing Email

The breach started with a phishing email, so I began with the mail server MAIL01 in the DMZ. In Kibana I filtered on the host MAIL01 and searched for SMTP activity with the term `*smtp*`. The 37 hits include several Postfix *smtpd* entries on 1 December 2024 at about 20:38 from the host **emkei.cz** at 114.29.236.247: the connection, an anonymous TLS session and a disconnect after the EHLO and STARTTLS exchange.

emkei.cz is a public service that sends email with a forged sender, which makes it a common tool for phishing. A VirusTotal check of the domain shows 9 of 92 vendors flagging it as malicious, mostly as phishing. Its appearance in the mail logs just before the first malicious file reached a workstation makes it the origin of the email that started the incident.

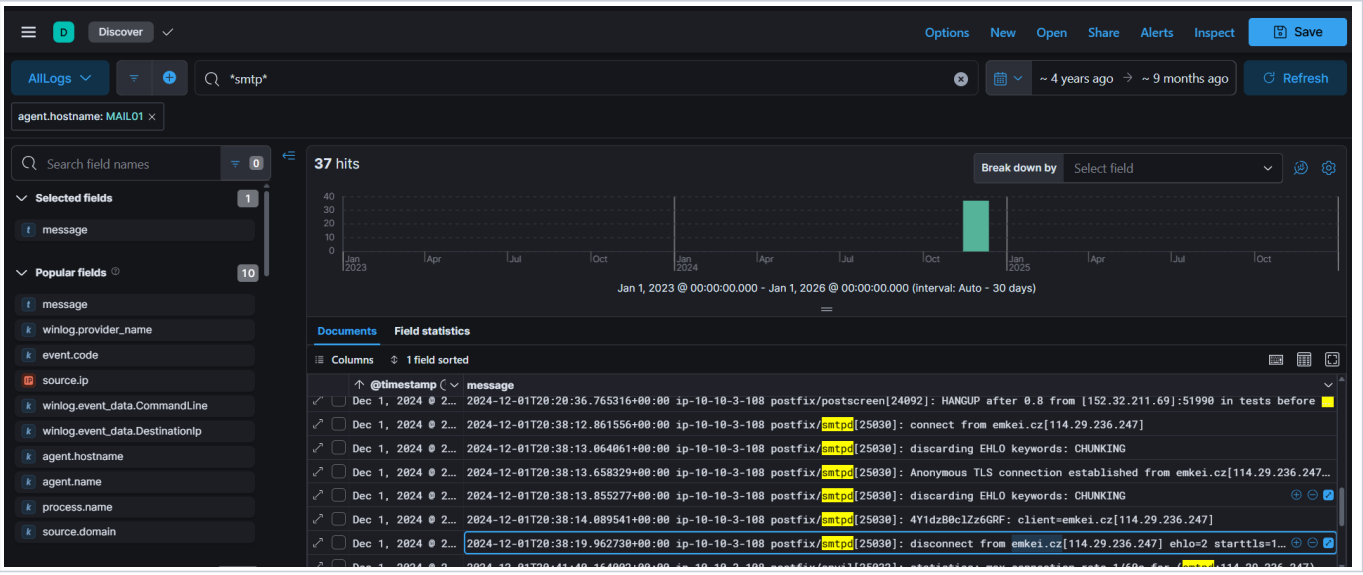


Figure 1. Postfix SMTP entries on MAIL01 showing connections from emkei.cz (114.29.236.247) on 1 December 2024.

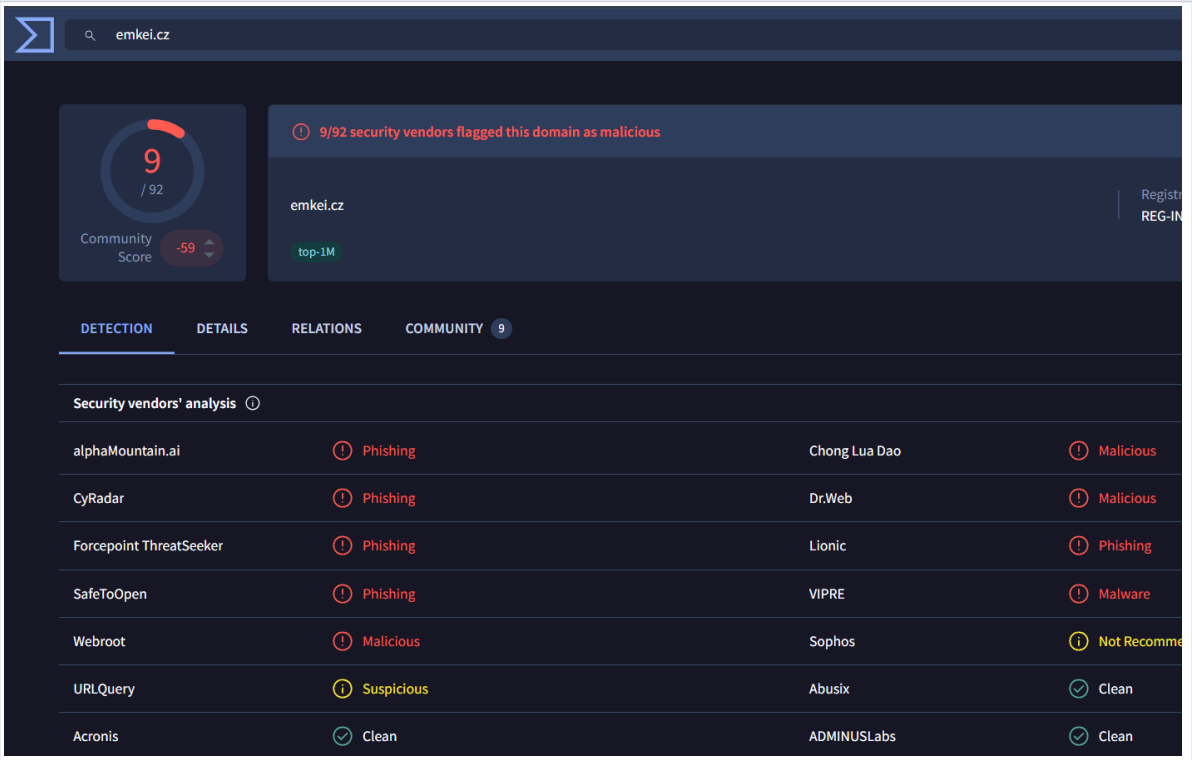


Figure 2. VirusTotal reputation of emkei.cz: 9 of 92 vendors flag the domain, mainly as phishing.

Phase 2 - Malicious File Downloaded Through Webmail

Next I looked for files created as a result of the user acting on the email. Sysmon event IDs 11 (FileCreate) and 15 (FileCreateStreamHash), filtered on paths containing *Download*, show activity in the Downloads folders of IT01 (the Administrator profile) and Support01 (the markw profile). On IT01 at about 21:02, **chrome.exe** created `NovaSecure_Audit_Findings.iso` together with its `Zone.Identifier` alternate data stream.

The Zone.Identifier stream holds a ZoneTransfer entry with ZoneId=3, which marks the file as coming from the internet, and its referrer and host URLs point to the company webmail interface. That confirms the ISO arrived through the mail system. Expanding the stream-hash event for the ISO itself gives its SHA256 hash, which I recorded as an indicator (section 7).

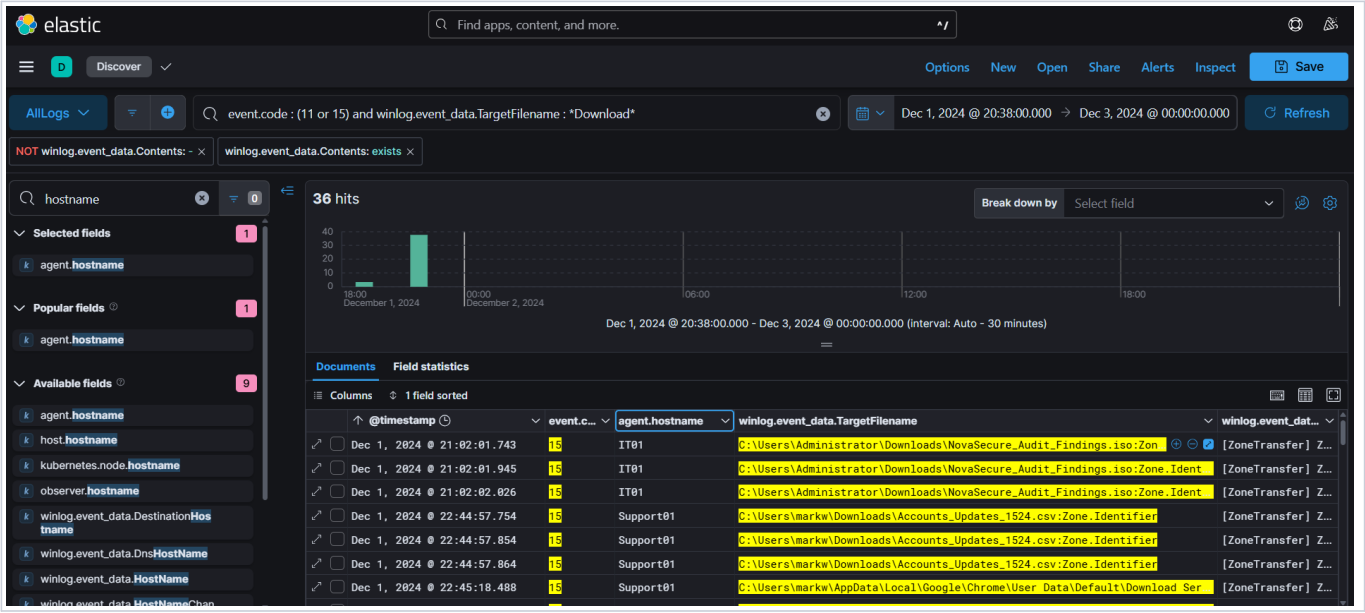


Figure 3. File creation events in the Downloads folders: the ISO on IT01 and a CSV file on Support01.

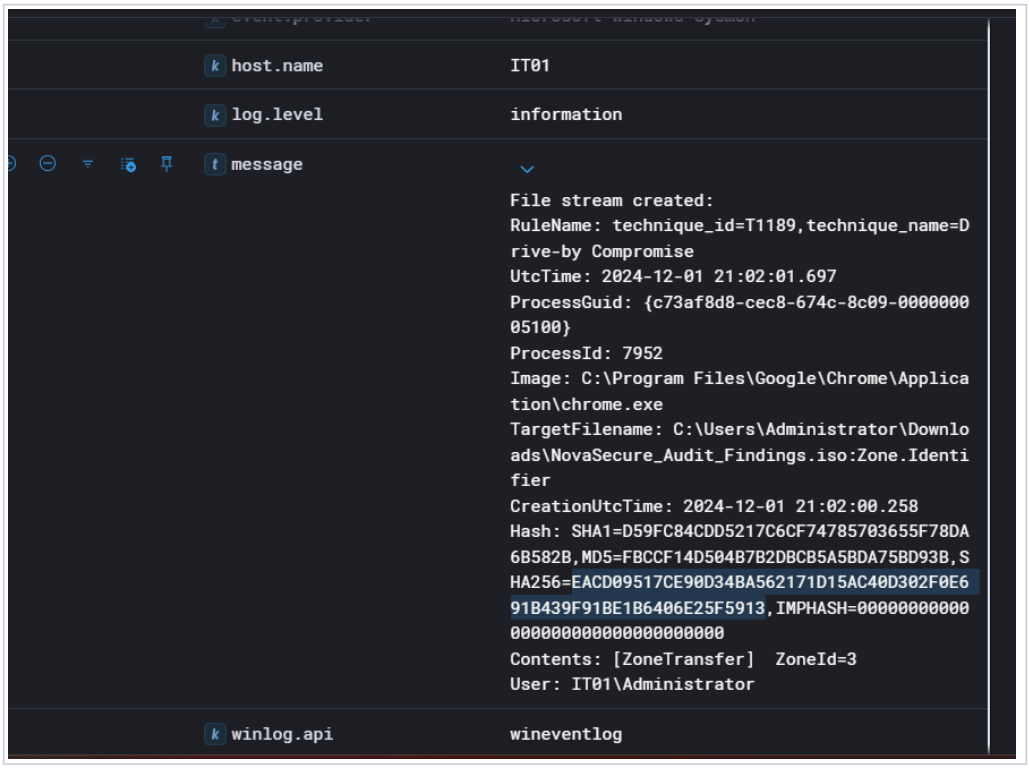


Figure 4. Zone.Identifier event for the ISO on IT01: created by chrome.exe, ZoneId=3, user IT01\Administrator.

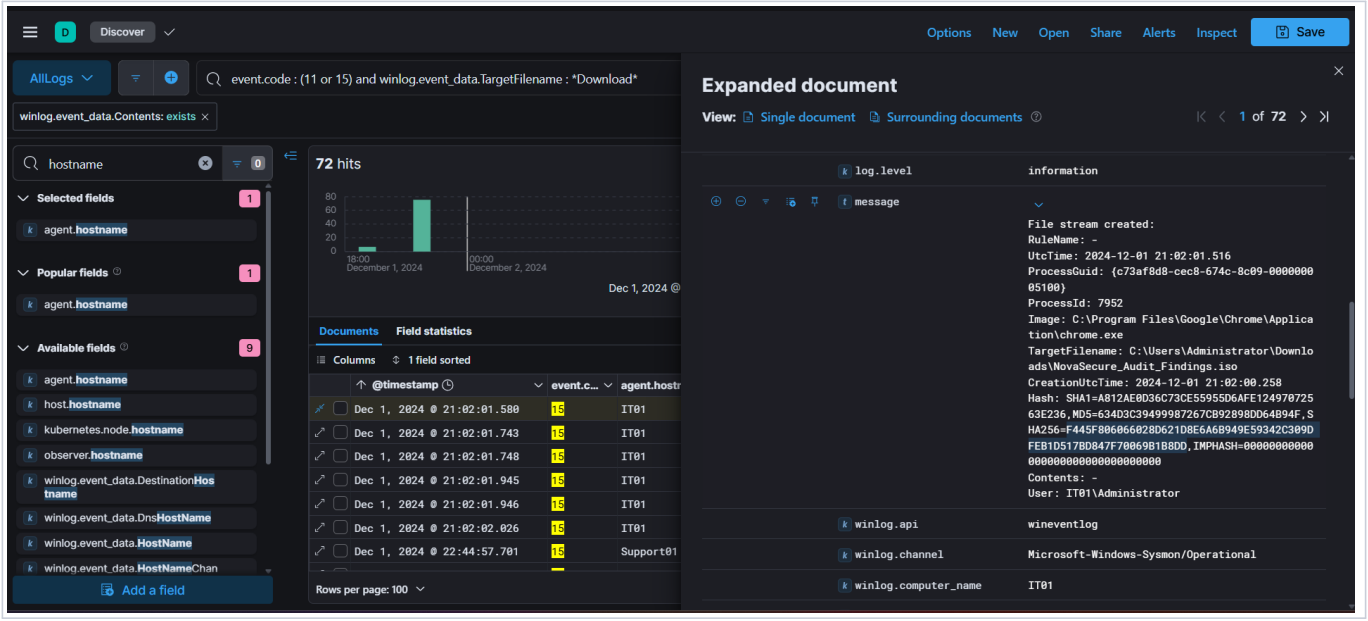


Figure 5. Stream-hash event for NovaSecure_Audit_Findings.iso with the SHA256 hash highlighted.

Phase 3 - Execution Through the ISO, Shortcut and DLL

I then followed the ISO on IT01 with process creation events (Event ID 1). At 21:02:17 the 7-Zip GUI process `7zG.exe`, started from explorer.exe, extracted the image into `C:\Users\Administrator\Downloads\NovaSecure_Audit_Findings\`. File creation events for that folder list the extracted content: **Compliance_Reports.lnk**, a DLL named **23.dll** and documents with audit-style names such as `Critical_Findings_Summary.pdf`.

At 21:02:57 a process creation event shows `rundll32.exe 23.dll, StartW` with explorer.exe as the parent process and the Administrator account as the user. A parent of explorer.exe means the execution came from a user action, not from a scheduled task or service: the user opened the shortcut, which was built to run rundll32.exe with the DLL instead of opening a report. rundll32.exe is a legitimate Windows component that is often abused to run code from a DLL.

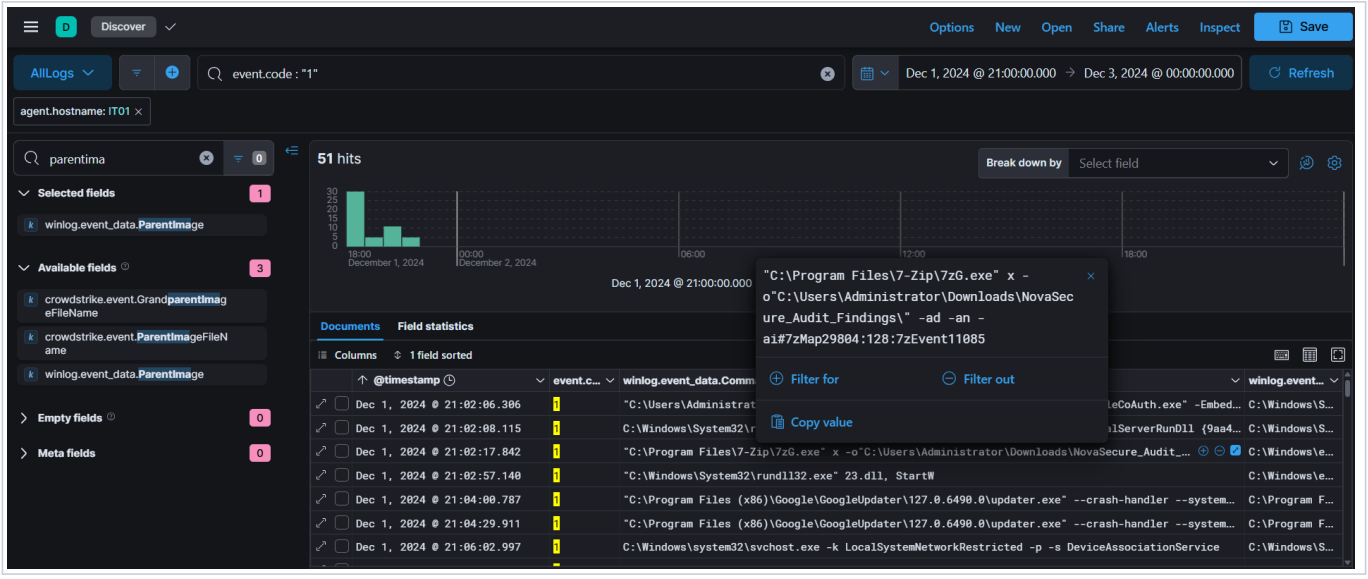


Figure 6. Process creation on IT01: 7-Zip extracting the ISO into the Downloads folder (full command line shown).

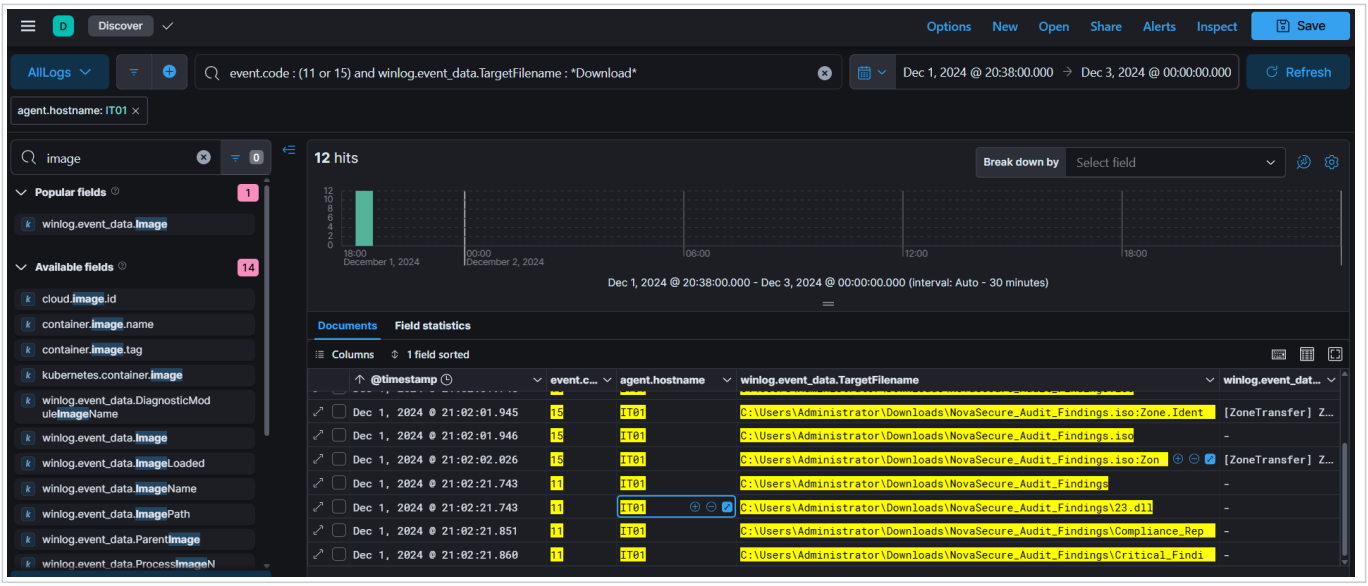


Figure 7. Files created while extracting the ISO: the folder, 23.dll, Compliance_Reports.lnk and the decoy documents.

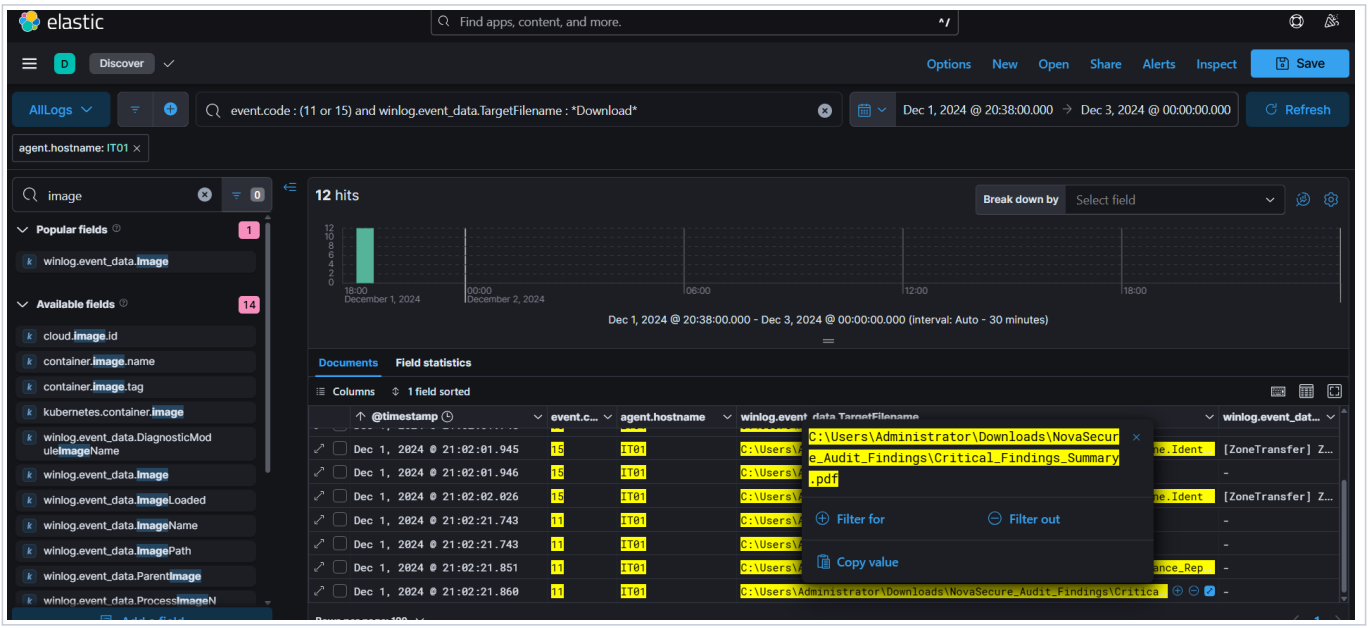


Figure 8. Full path of one of the decoy documents created inside the extracted folder.

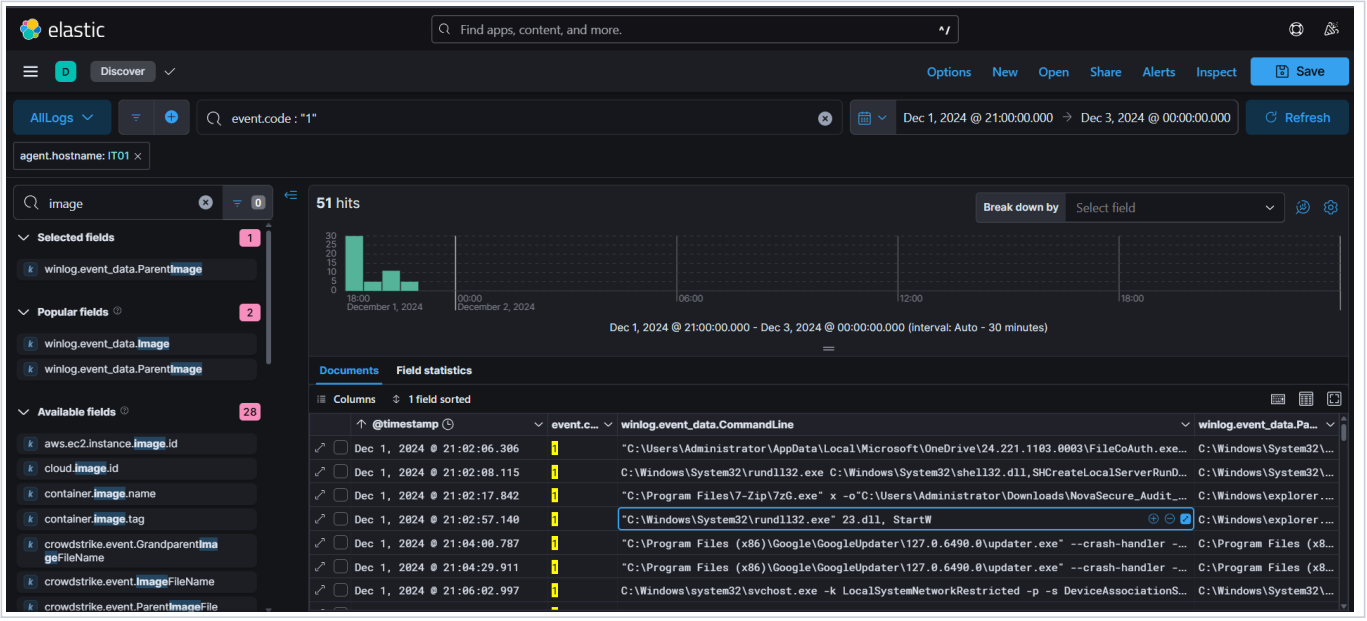


Figure 9. rundll32.exe loading 23.dll with the StartW export, started from explorer.exe at 21:02:57.

Phase 4 - Beacon Execution and Process Injection

The DLL gave the attacker a beacon. To see what it touched, I searched Sysmon process access and remote thread events (event codes 8 and 10) on IT01, excluding the noisy OneDrive source. The results show **rundll32.exe** acting on **C:\Program Files\Windows Photo Viewer\ImagingDevices.exe**, a legitimate Windows binary that should not be launched from rundll32.exe, and later rows show ImagingDevices.exe itself acting on cmd.exe.

The CreateRemoteThread event at 21:09:27 makes the injection explicit: rundll32.exe (PID 4764) created a thread in ImagingDevices.exe (PID 9220) with the start address `0x000001C75CB60000` and no start module or function. Code that starts at an address not backed by a module is a typical sign of injected code. By running inside a signed Windows binary the attacker hides the beacon from tools that watch only for new processes. The StartW export, the injection and the behavior that follows are consistent with a Cobalt Strike beacon.

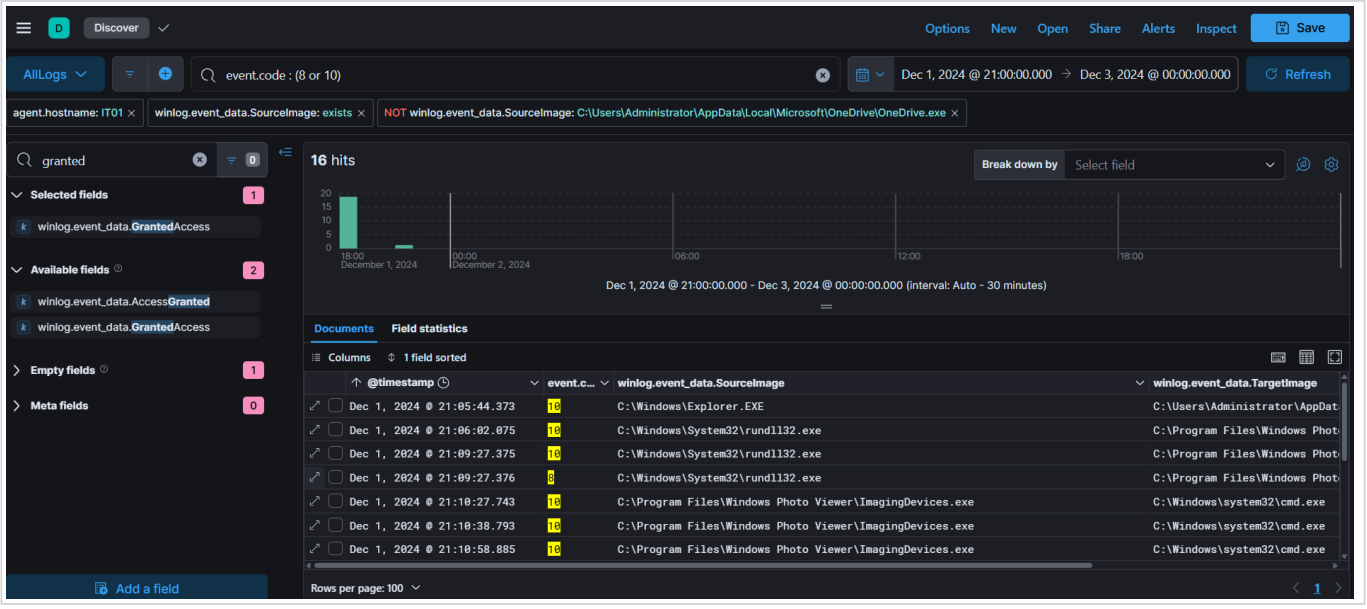
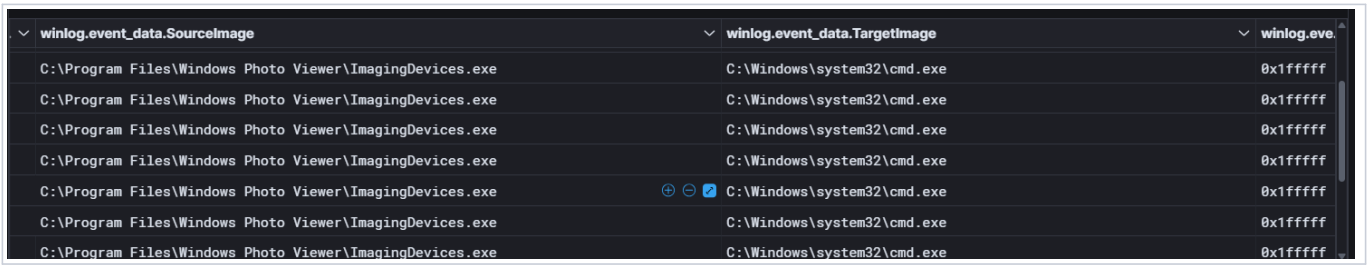


Figure 10. Process access and remote thread events on IT01: rundll32.exe targeting ImagingDevices.exe.



winlog.event_data.SourceImage	winlog.event_data.TargetImage	winlog.eve
C:\Program Files\Windows Photo Viewer\ImagingDevices.exe	C:\Windows\system32\cmd.exe	0x1fffff
C:\Program Files\Windows Photo Viewer\ImagingDevices.exe	C:\Windows\system32\cmd.exe	0x1fffff
C:\Program Files\Windows Photo Viewer\ImagingDevices.exe	C:\Windows\system32\cmd.exe	0x1fffff
C:\Program Files\Windows Photo Viewer\ImagingDevices.exe	C:\Windows\system32\cmd.exe	0x1fffff
C:\Program Files\Windows Photo Viewer\ImagingDevices.exe	C:\Windows\system32\cmd.exe	0x1fffff
C:\Program Files\Windows Photo Viewer\ImagingDevices.exe	C:\Windows\system32\cmd.exe	0x1fffff
C:\Program Files\Windows Photo Viewer\ImagingDevices.exe	C:\Windows\system32\cmd.exe	0x1fffff

Figure 11. Later rows of the same search: ImagingDevices.exe acting on cmd.exe, which is used to run the attacker commands.

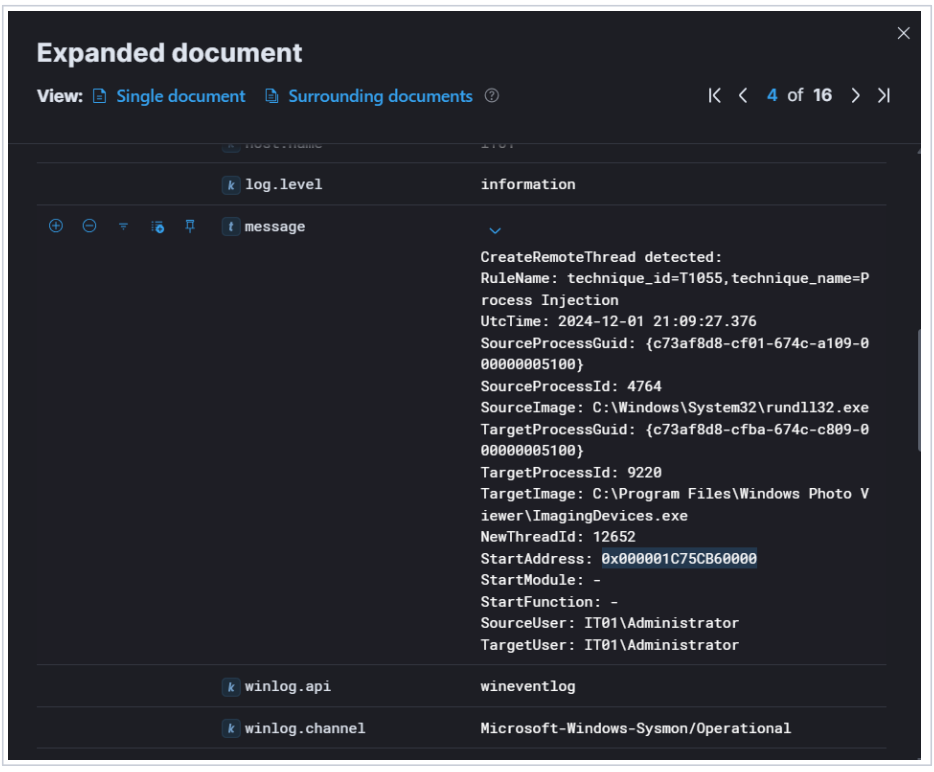


Figure 12. CreateRemoteThread event (T1055 Process Injection): rundll32.exe into ImagingDevices.exe, start address highlighted.

Phase 5 - Discovery on IT01

With the beacon running inside ImagingDevices.exe, the attacker started hands-on discovery. Process creation events on IT01 with ImagingDevices.exe as the parent show `ipconfig /all`, `arp -a`, `nbtstat -n` and a ping to the domain name ad.compliantsecure.store between 21:10 and 21:11, which maps the local network and locates the domain controller. At 21:12:05 the attacker ran `nltest /domain_trusts` to list the domain trust relationships, which can reveal paths for lateral movement.

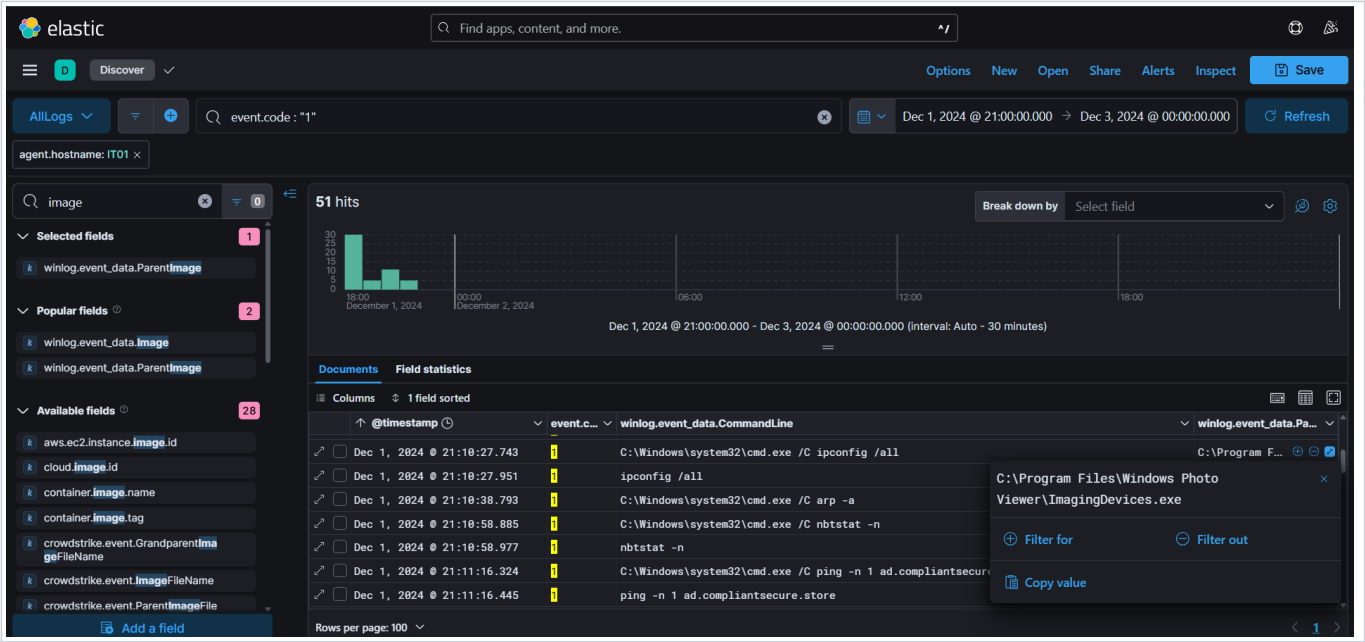


Figure 13. Discovery commands run from the injected process: ipconfig, arp, nbtstat and a ping to the domain.

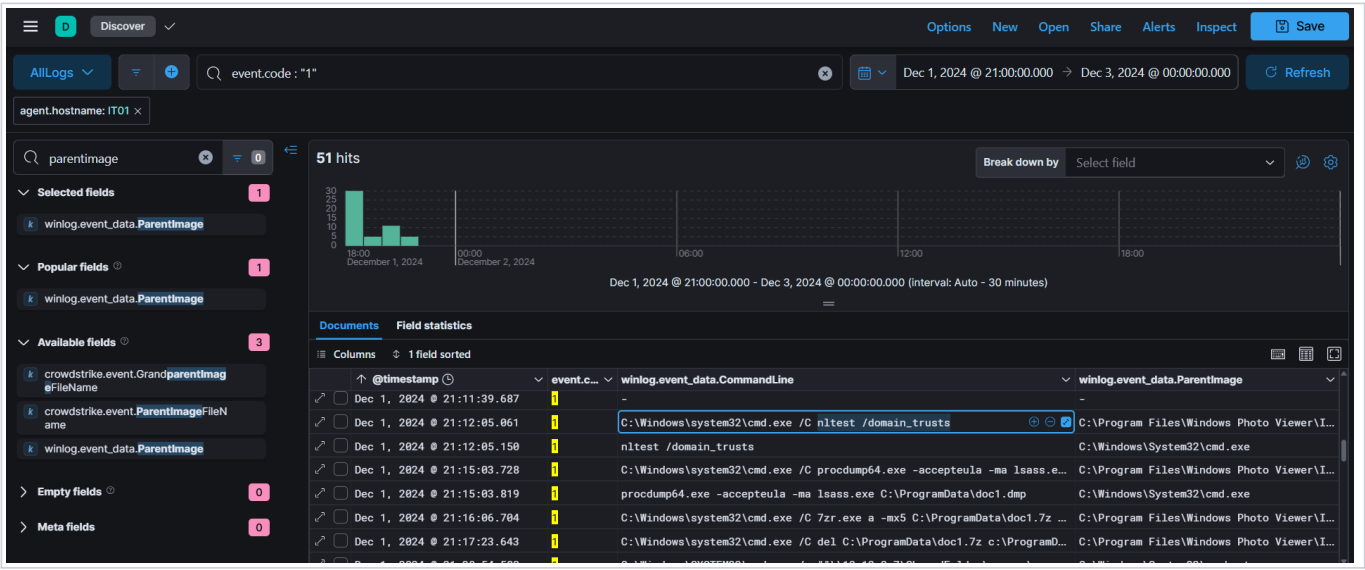


Figure 14. Domain trust discovery with nltest at 21:12:05, followed by the credential dumping commands.

Phase 6 - Credential Dumping and Tool Staging

Credential theft usually targets the LSASS process, so I looked at process access events (Sysmon event ID 10) where lsass.exe is the target. The results show `C:\ProgramData\procdump64.exe` accessing LSASS repeatedly. ProcDump is a legitimate Microsoft Sysinternals tool, which makes it attractive to attackers because it may already be allowed in the environment.

File creation events on IT01 show how the tools arrived: procdump64.exe was written to C:\ProgramData at 21:13:35 and the standalone 7-Zip utility `C:\ProgramData\7zr.exe` at 21:15:43, both by the injected process. At 21:15:03 the process creation event shows the command `procdump64.exe -accepteula -ma lsass.exe C:\ProgramData\doc1.dmp`, a full memory dump of LSASS. At 21:16:06 the dump was compressed with `7zr.exe a -mx5 doc1.7z doc1.dmp` and at 21:17:23 both files were deleted with `del`. Deleting the dump after archiving removes the evidence from disk and is consistent with the archive having been taken off the host through the

beacon. Later activity authenticates with the domain administrator account **markw**, consistent with credentials recovered from this dump.

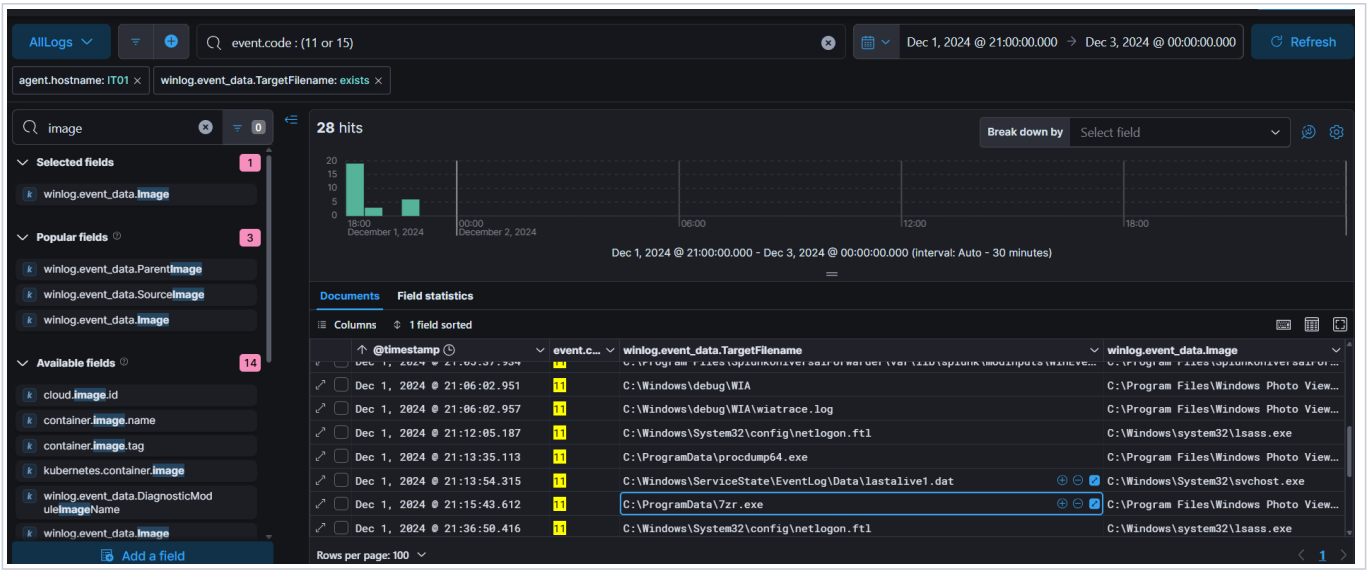


Figure 15. File creation events on IT01: procdump64.exe and 7zr.exe dropped in C:\ProgramData by the injected process.

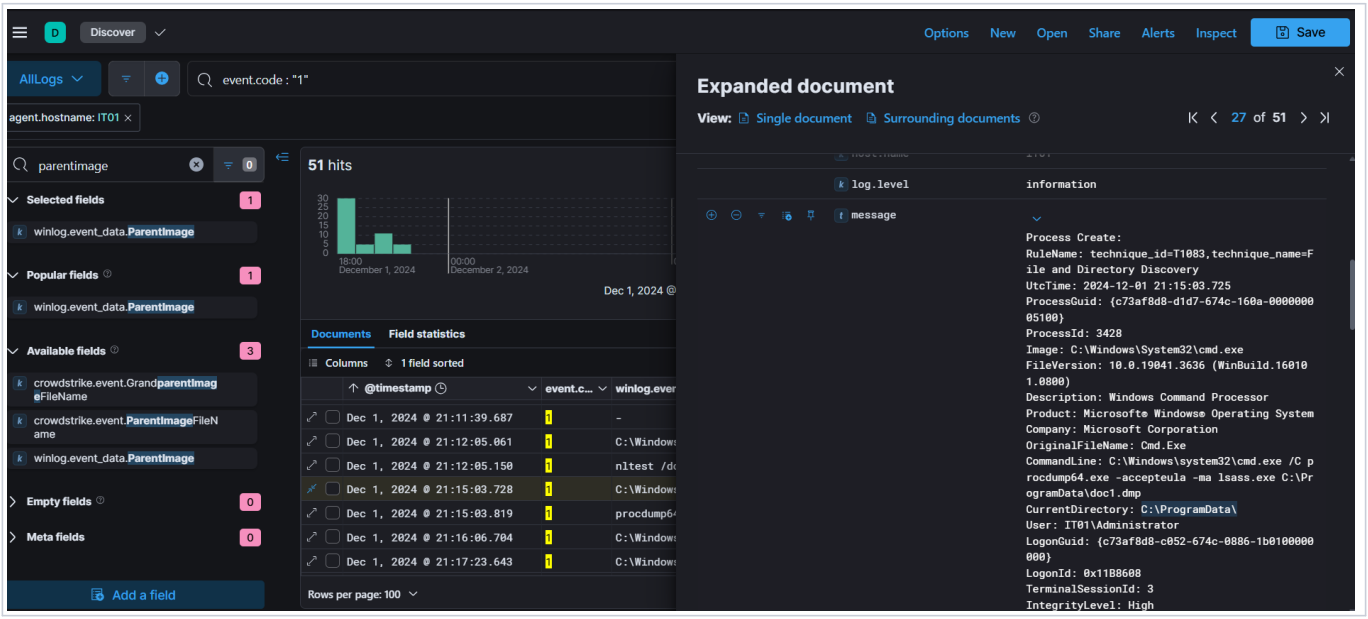


Figure 16. Process creation event for the ProcDump command that dumps LSASS to C:\ProgramData\doc1.dmp.

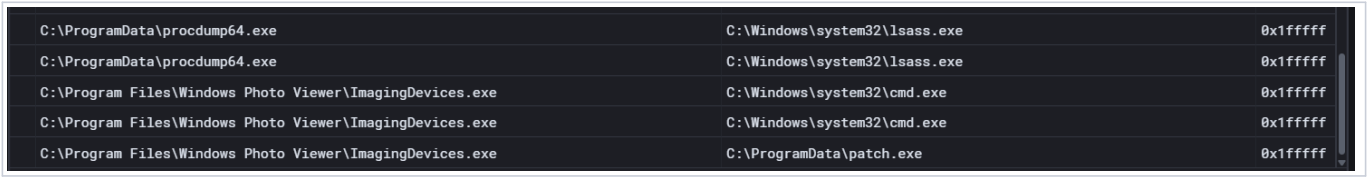


Figure 17. Process access events: procdump64.exe accessing lsass.exe (and ImagingDevices.exe reaching other processes).

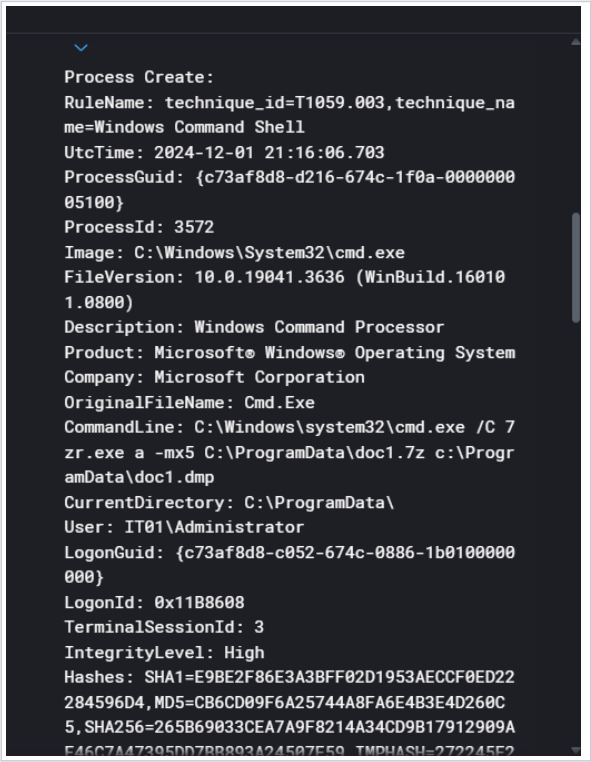


Figure 18. Process creation event: cmd.exe compressing the dump with 7zr.exe (mx5) at 21:16:06.

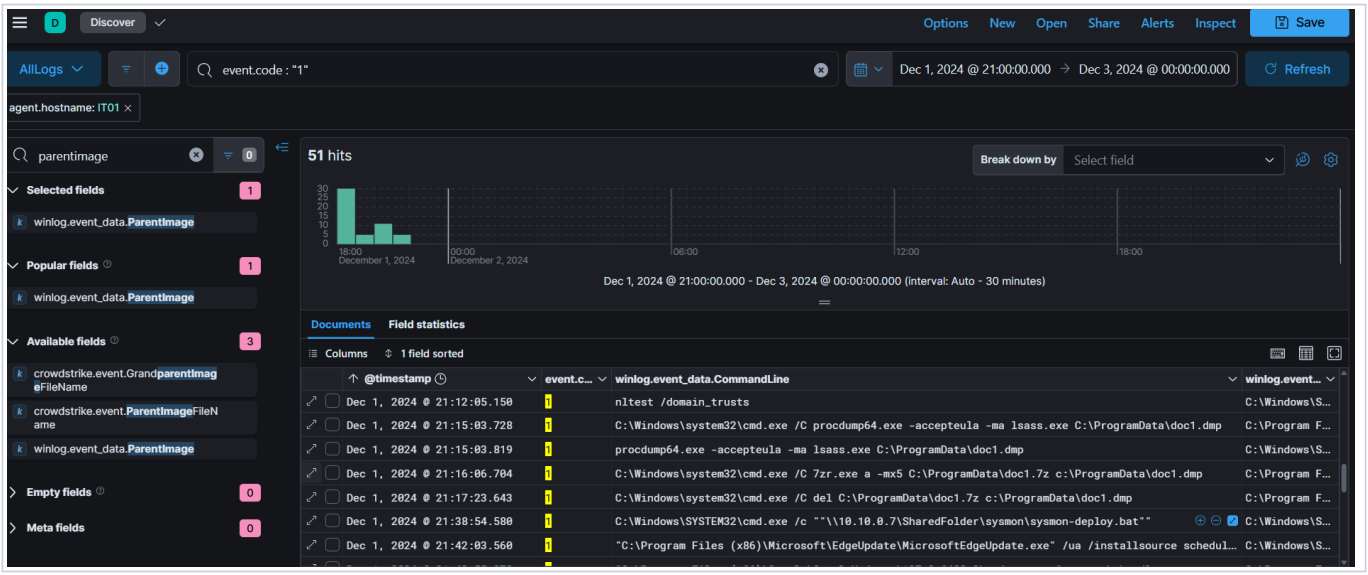


Figure 19. The sequence on IT01: nltest, ProcDump, 7zr archive, then deletion of doc1.7z and doc1.dmp.

Phase 7 - Lateral Movement to the Domain Controller

To find which account was used against the domain controller, I filtered successful logons (Event ID 4624) on DC01 after the LSASS dump and excluded the computer accounts, whose names end with a dollar sign. Among 150 events the user account **markw** stands out, because a domain administrator account should not appear this often in logons to a domain controller.

On IT01, Event ID 4648 (a logon attempted with explicit credentials) shows the system process (PID 4) using markw credentials against DC01.ad.compliantsecure.store. The expanded event gives the target address 10.10.11.156 on **port 445**, which is SMB, the protocol used for file sharing and remote administration. Over SMB the attacker copied

an executable to DC01: file creation events show `C:\Windows\0453497.exe` created at 22:03:41. A seven-character random name like this matches the default naming of Cobalt Strike service beacons. At 22:04:02 Event ID 7045 shows a service called **0453497** installed with the image path `\\10.10.11.156\ADMIN$\0453497.exe`, so the beacon now runs on the domain controller as a service.

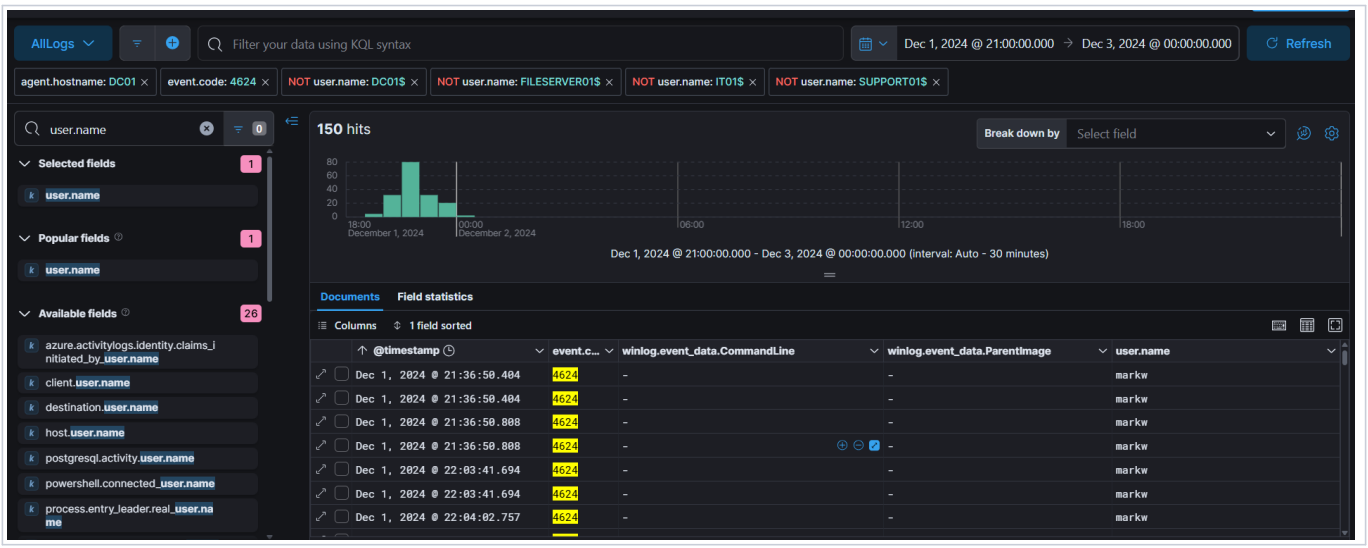


Figure 20. Successful logons (4624) on DC01 excluding machine accounts: the markw account dominates.

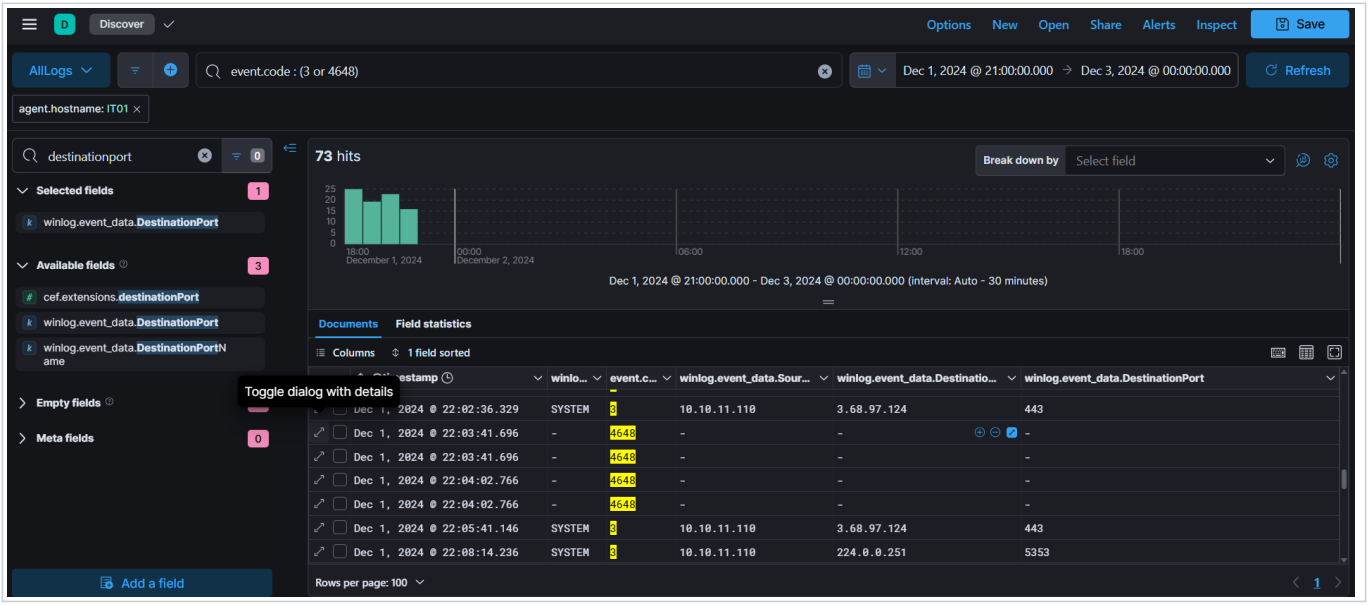


Figure 21. Explicit-credential logons (4648) on IT01 alongside the outbound connections of the beacon.

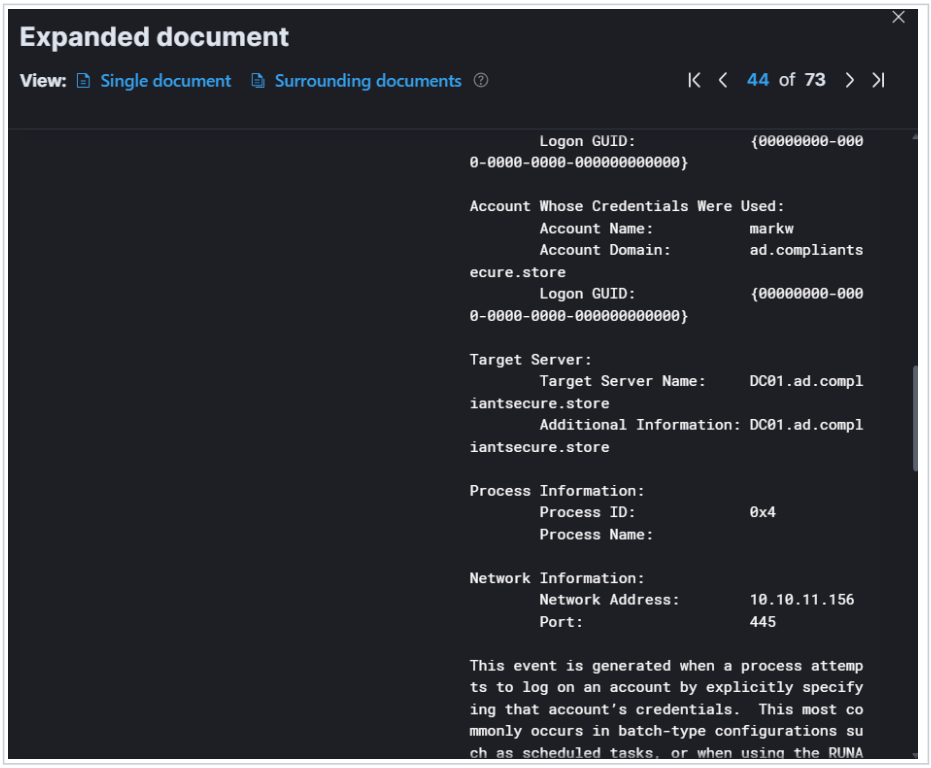


Figure 22. Expanded 4648 event: markw credentials used against DC01.ad.compliantsecure.store, target 10.10.11.156 port 445.

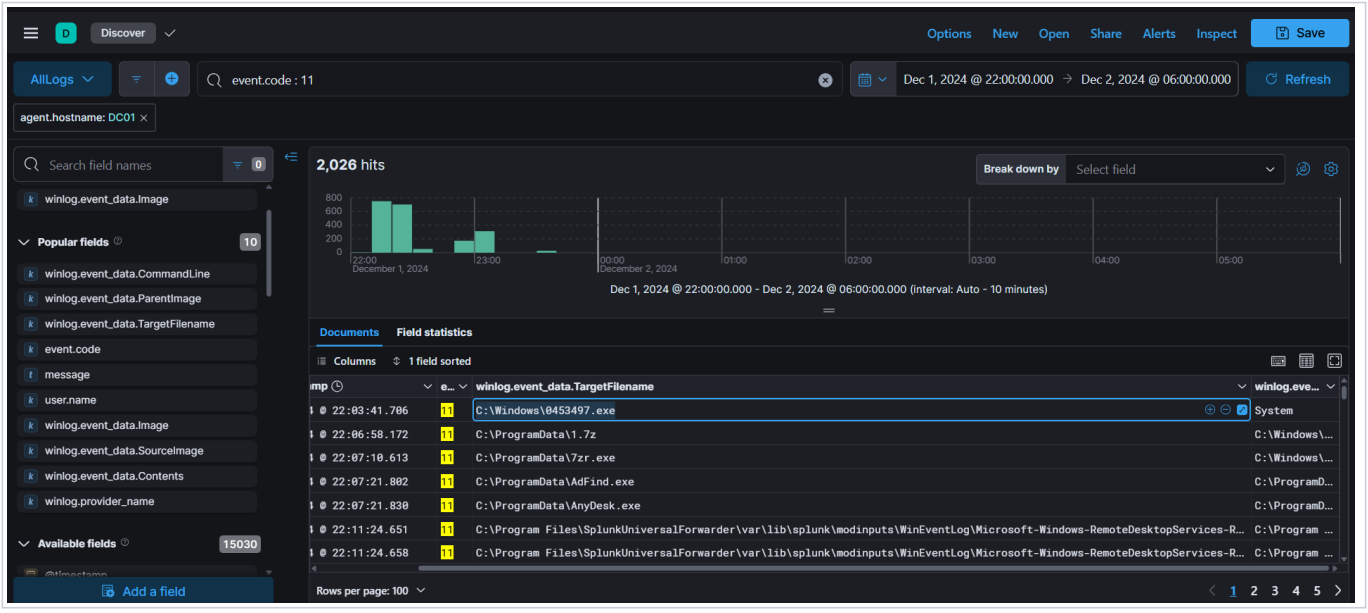


Figure 23. File creation events on DC01: C:\Windows\0453497.exe, then 1.7z, 7zr.exe, AdFind.exe and AnyDesk.exe in C:\ProgramData.

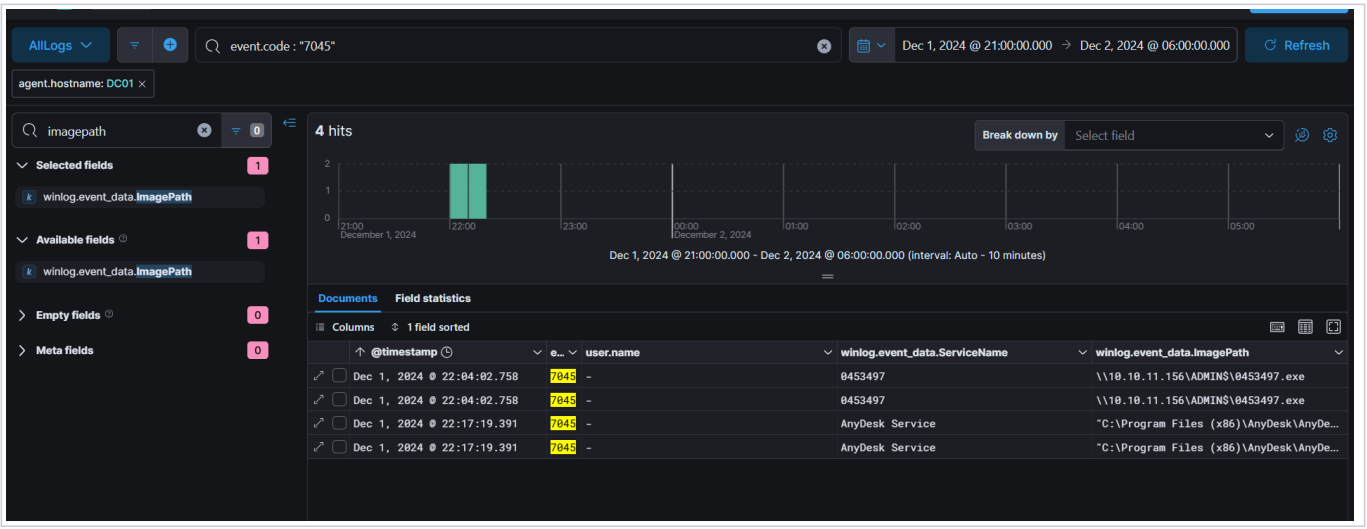


Figure 24. Service installation events (7045) on DC01: service 0453497 pointing to the ADMIN$ share, later the AnyDesk service.

Phase 8 - Tool Staging and Network Scanning on DC01

On DC01 the process creation events show the beacon at work. The first row in the view below is rundll32.exe whose parent is the service executable `\\10.10.11.156\ADMIN$\0453497.exe`, which links the service to the beacon. The file creation events seen earlier show the attacker dropped an archive **1.7z**, the extraction utility 7zr.exe, **AdFind.exe** (a tool for Active Directory enumeration) and AnyDesk.exe in C:\ProgramData. At 22:07:21 the attacker unpacked the archive with `C:\Windows\system32\cmd.exe /C 7zr.exe x 1.7z`. The `x` option extracts the contents with their full paths into the current directory, C:\ProgramData.

Around 22:27 the attacker ran a script, `C:\Users\sql_admin\Desktop\1.bat`, through cmd.exe. Right after it, one-packet pings (`ping -n 1`) go to IT01, DC01, Support01 and FileServer01 under ad.compliantsecure.store. Using a script to send a single echo request to each key system is a quick, low-noise way to confirm reachability of the targets.

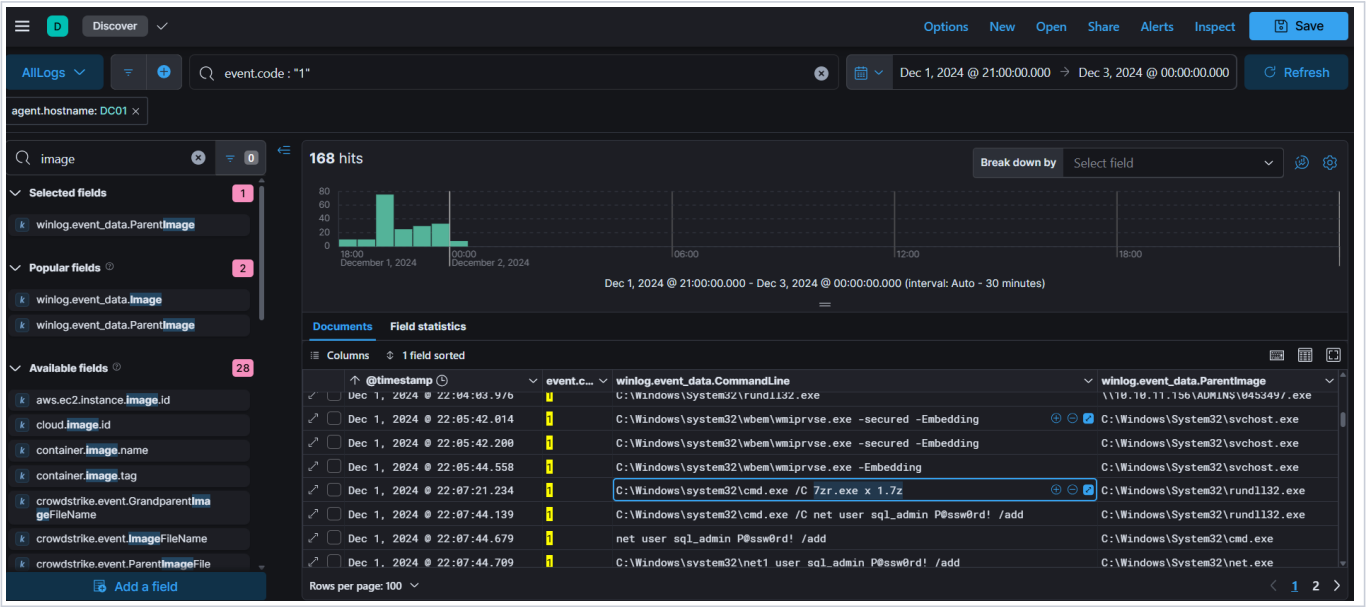


Figure 25. DC01 process creation: service executable as parent of rundll32.exe, then 7zr.exe extracting 1.7z.

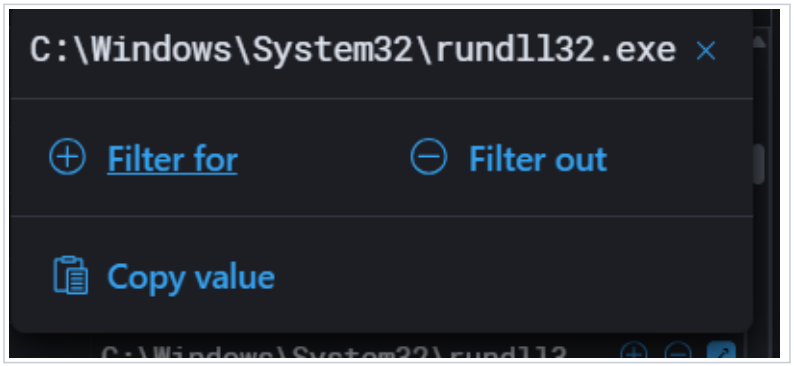


Figure 26. Parent image of the beacon process on DC01: C:\Windows\System32\rundll32.exe.

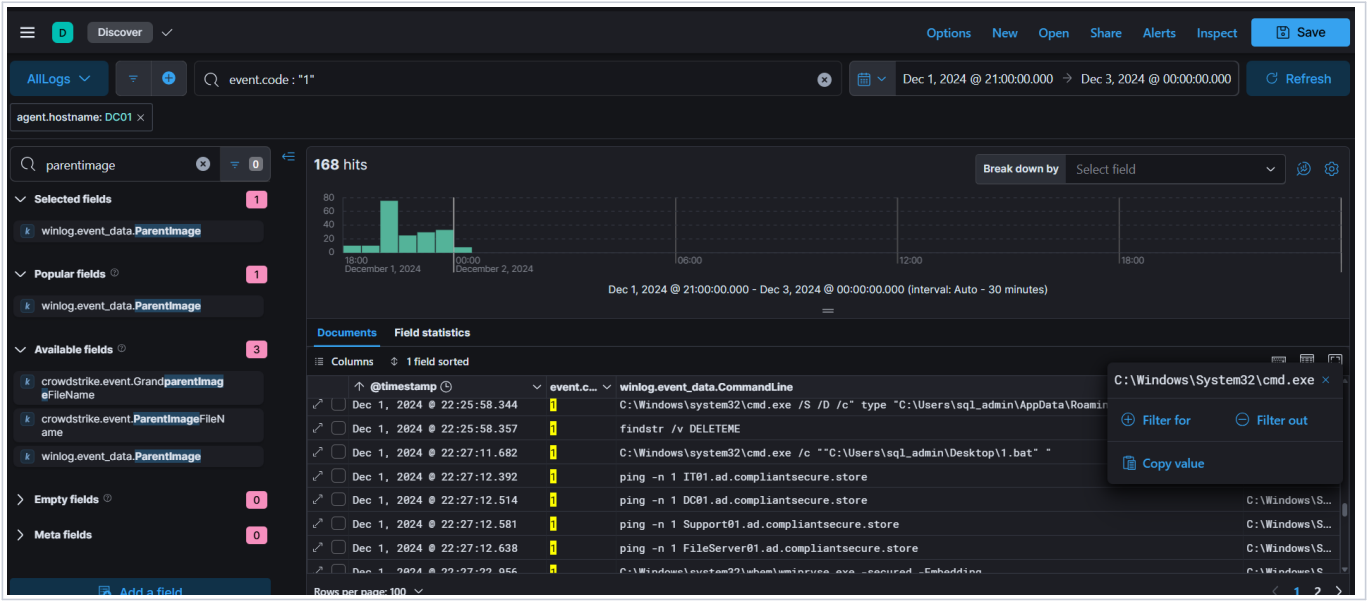


Figure 27. Reachability script on DC01: 1.bat followed by single pings to the key servers and workstations.

Phase 9 - Remote Desktop Access From the Attacker Workstation

To find how the attacker worked interactively, I searched Event IDs 4624 and 4776 on DC01 for the markw account. Event ID 4776 is written every time NTLM credentials are validated and it records the name of the workstation they came from. The early network logons (type 3) at 21:36 and 22:03 list IT01 as the workstation. At 22:12:12 two logons with **logon type 10** appear, which is a remote interactive logon, that is, Remote Desktop. The validation events written just before them, at 22:12:06, name the workstation **EC2AMAZ-NVLPEI1**, the attacker machine, which carries the default naming pattern of a cloud-hosted Windows instance.

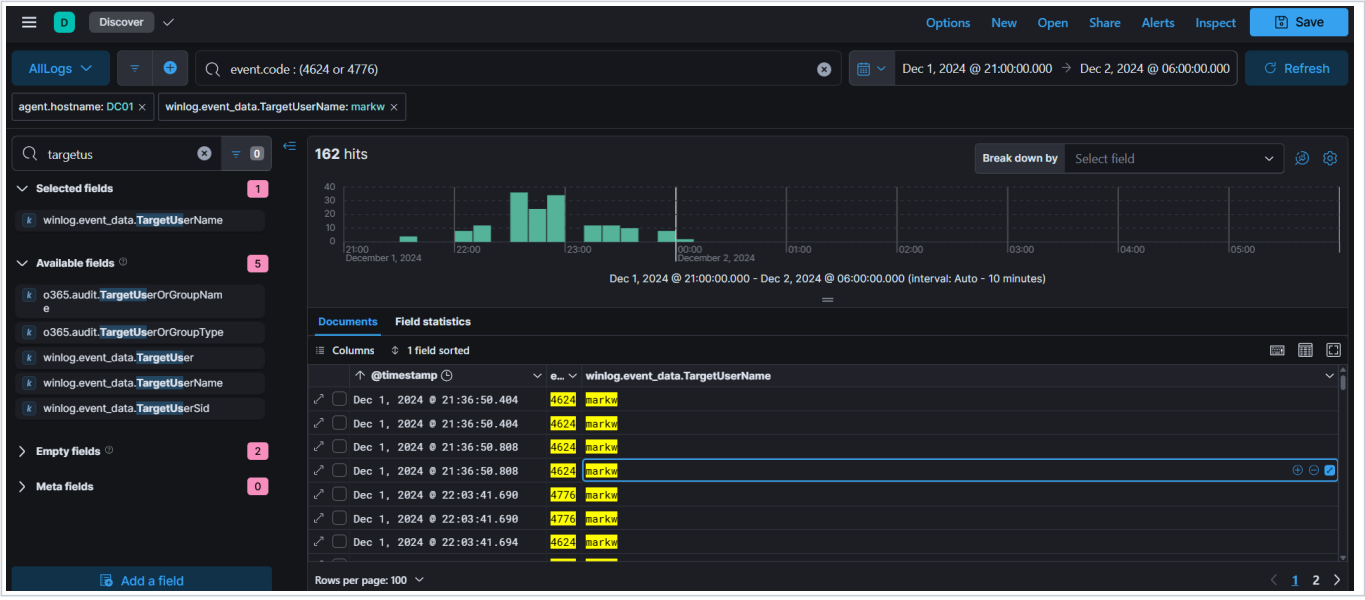


Figure 28. Logons (4624) and credential validations (4776) for markw on DC01.

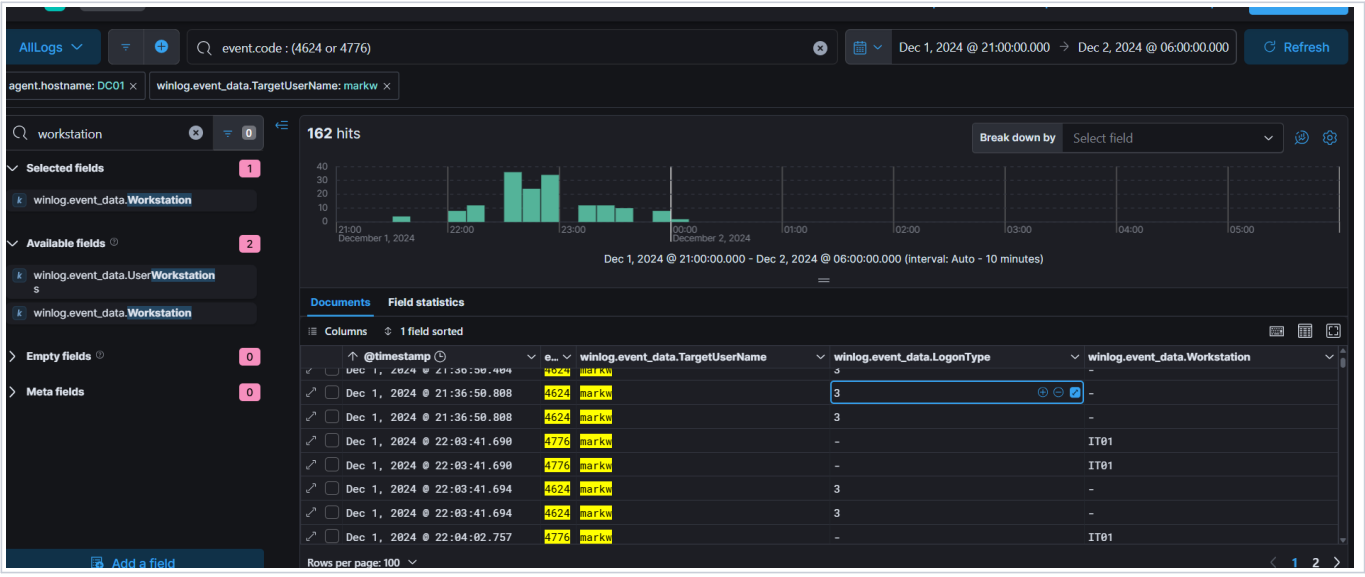


Figure 29. Same search with the logon type and workstation columns: type 3 logons and IT01 as the validated workstation.



Figure 30. RDP logons (type 10) at 22:12:12 and the validation events naming EC2AMAZ-NVLPEI1.

Phase 10 - Persistence on the Domain Controller

The attacker did not rely on the beacon alone. Three persistence mechanisms appear on DC01, in this order.

Malicious service. The service 0453497 described in Phase 7 runs the beacon executable with SYSTEM privileges, independently of any user logon, and restarts with the system.

Rogue administrator account. At 22:07:44 and 22:07:54 process creation events show `net user sql_admin <password> /add` and `net localgroup Administrators sql_admin /ADD`. The account was created with a weak, guessable password and added to the Administrators group. Security Event ID 4720 confirms the account creation. The name imitates a legitimate SQL administration account to blend in.

Remote access tool. AnyDesk.exe was dropped at 22:07:21. At 22:17:19 Event ID 7045 shows the *AnyDesk Service* installed, and at 22:17:20 AnyDesk.exe was started from explorer.exe with the *--control* and *--new-install* options. The first interactive logon (logon type 2) of sql_admin on DC01 follows at 22:25:02, with credential validations at 22:28. The attacker now had a way back in that does not depend on the beacon.

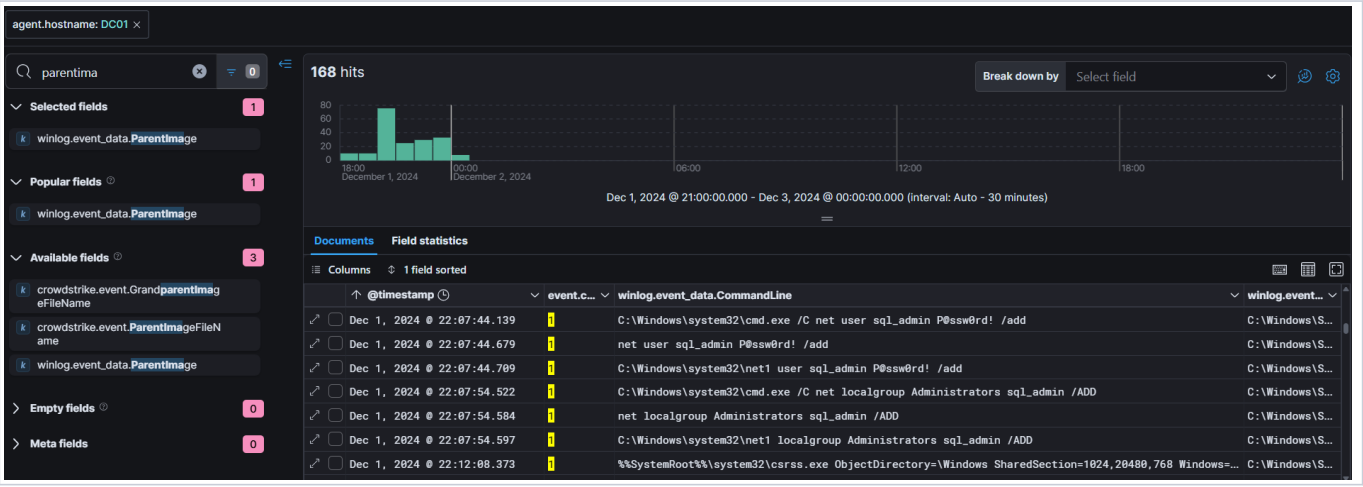


Figure 31. Account creation and group membership commands run on DC01.

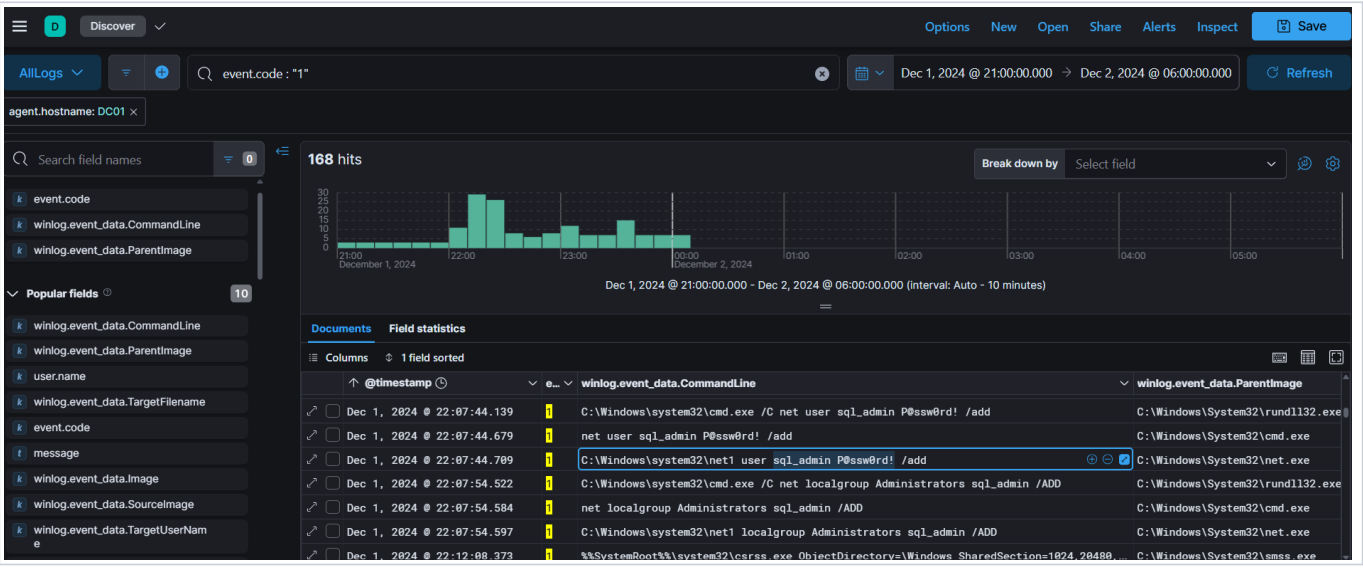


Figure 32. The net user command that creates sql_admin, with its parent process.

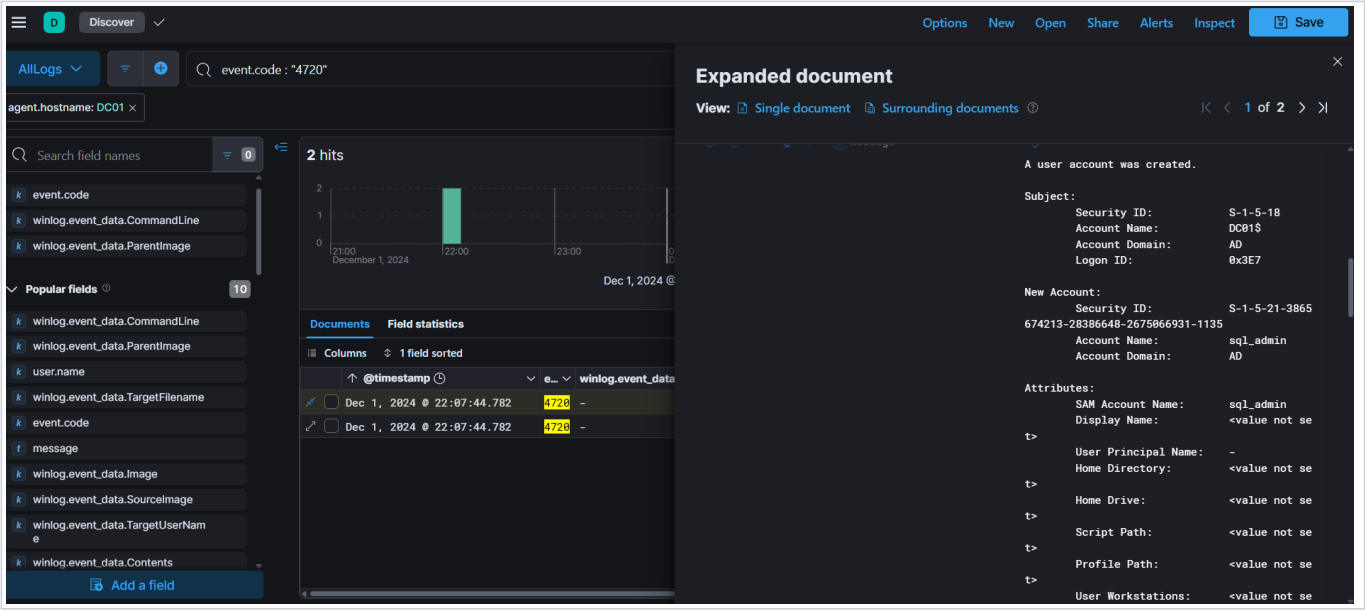


Figure 33. Event 4720: user account sql_admin created on DC01.

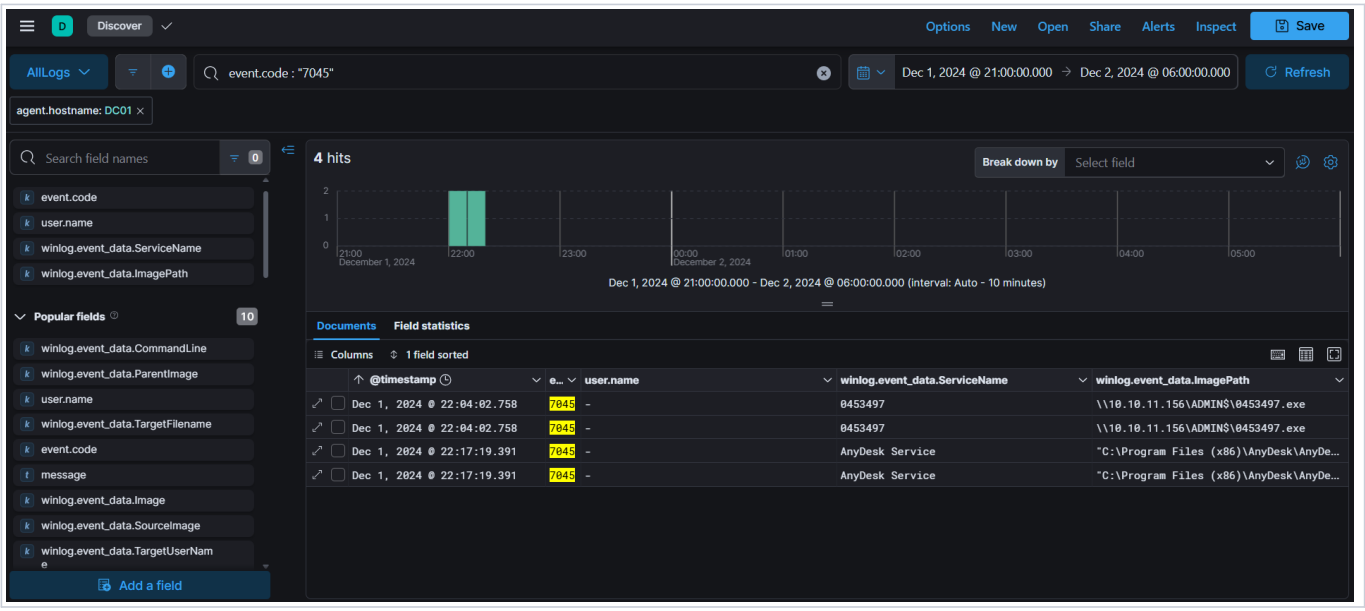


Figure 34. Event 7045: the AnyDesk service installed on DC01 at 22:17:19.

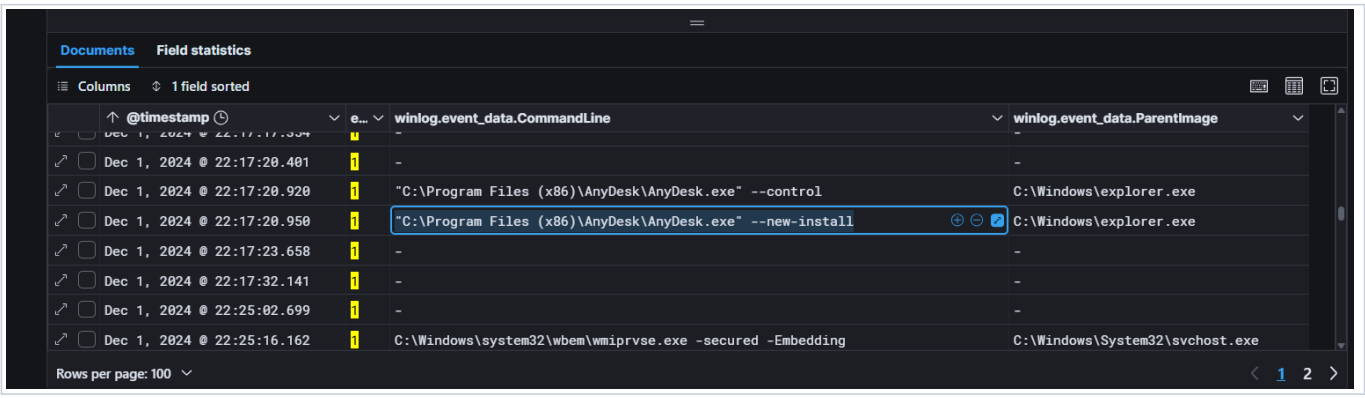


Figure 35. AnyDesk started from explorer.exe with --control and --new-install at 22:17:20.

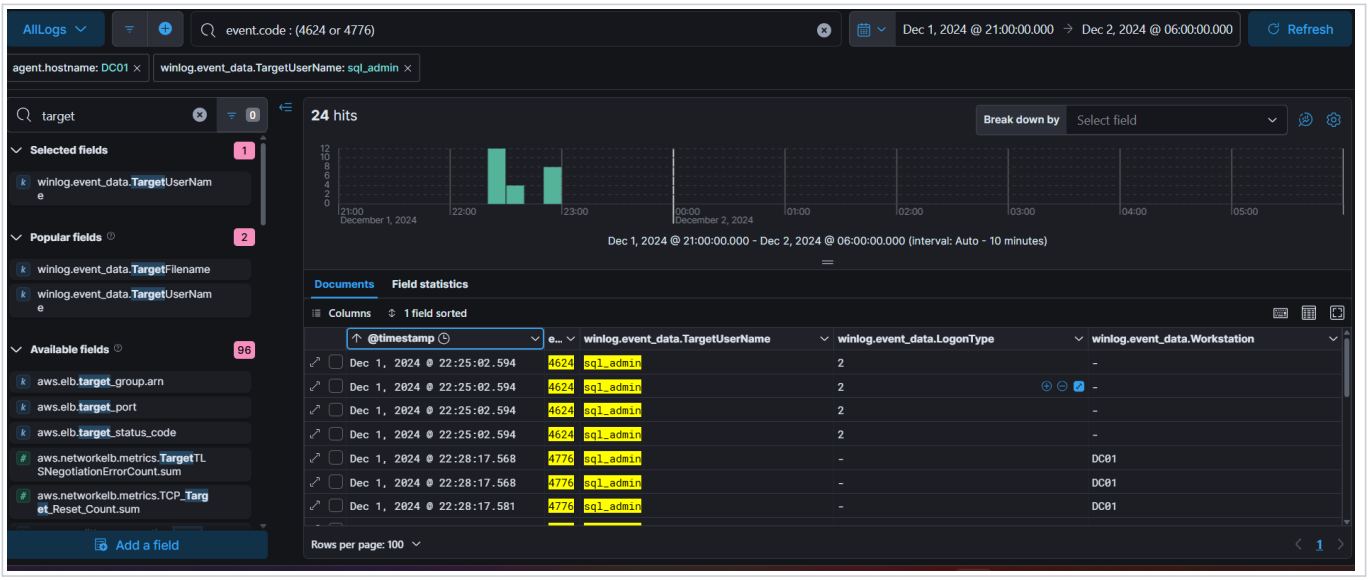


Figure 36. First interactive logon (type 2) of sql_admin at 22:25:02, followed by credential validations.

Phase 11 - Credential File Access and Data Collection

After the reconnaissance script, the attacker turned to the network shares. Process creation events for notepad.exe on DC01 show that at 22:29:46 the attacker opened `\\10.10.11.18\Shares\IT\Admin_Passwords_v3_HASHED.csv` from the file server. The name points to administrative credentials, even if stored as hashes, and shows sensitive material sitting in a broadly reachable share. A second Notepad execution, on Support01, opened the Accounts_Updates_1524.csv file covered in Phase 12.

At 22:31:34 Event ID 4624 on FILESERVER01 shows logon type 10 (RDP) for markw, coming from DC01. Process creation events on FILESERVER01 show the attacker compressing the shared content with 7-Zip into **Shares.7z**. The same activity appears on DC01, where a staging folder under the sql_admin desktop holds copies of internal documents (a policy manual and a compliance checklist) and Shares.7z is created at 22:38. Packaging everything into one archive is the usual preparation for exfiltration. The same views also contain other markw-profile activity (Startup folder access, csc.exe compilation, findstr) that I noted for further review.

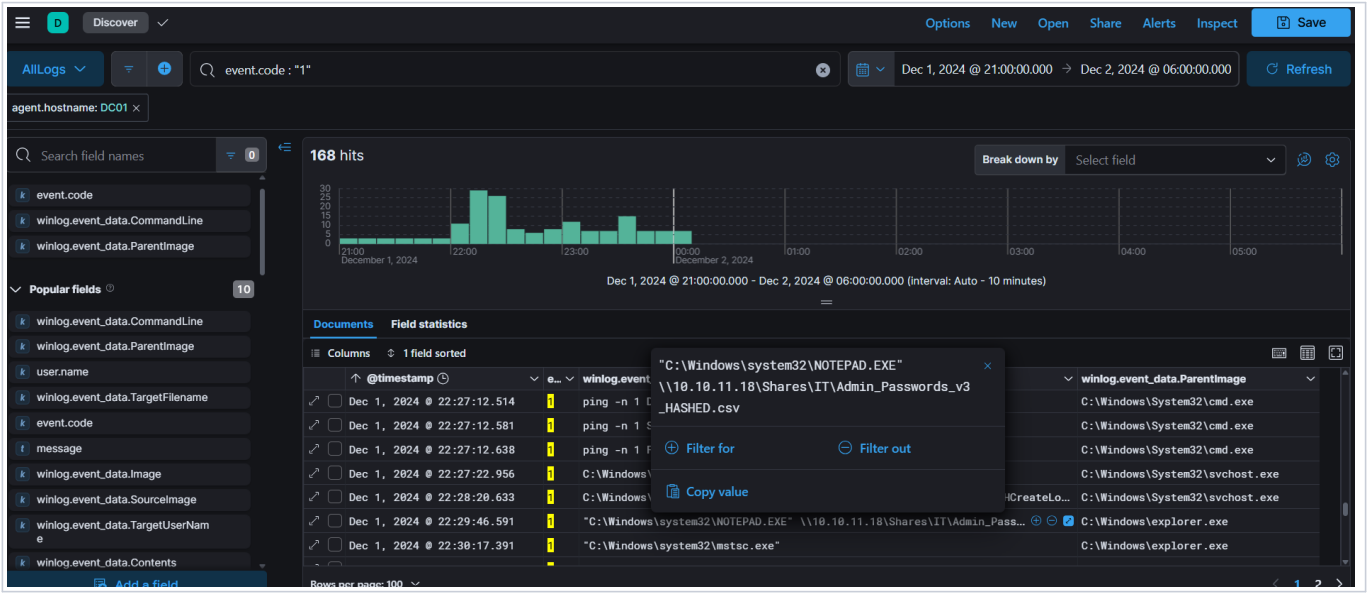


Figure 37. notepad.exe on DC01 opening Admin_Passwords_v3_HASHED.csv from the IT share on the file server.

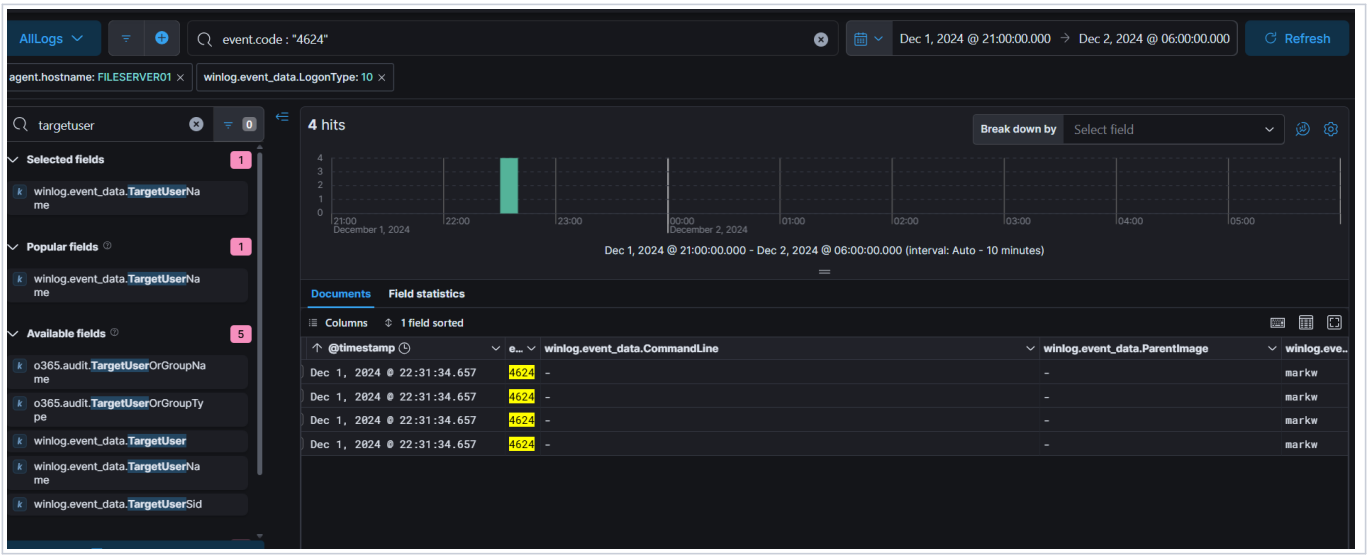


Figure 38. RDP logons (type 10) for markw on FILESERVER01 at 22:31:34.

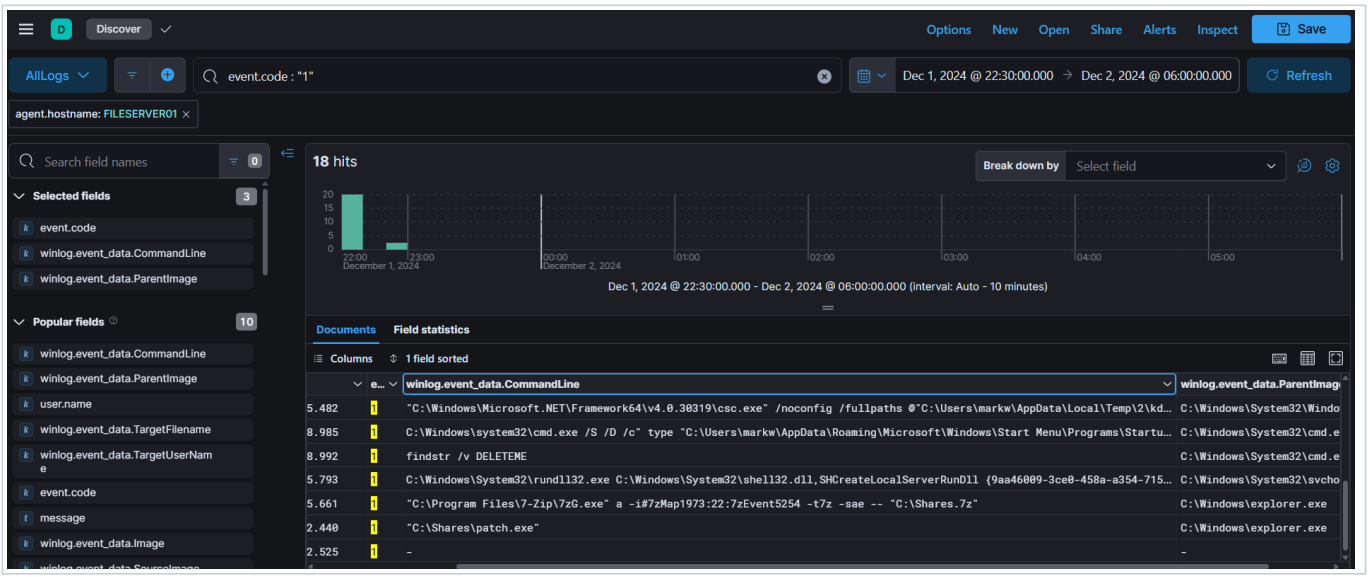


Figure 39. FILESERVER01 process creation: 7-Zip creating Shares.7z, and patch.exe launched from C:\Shares.

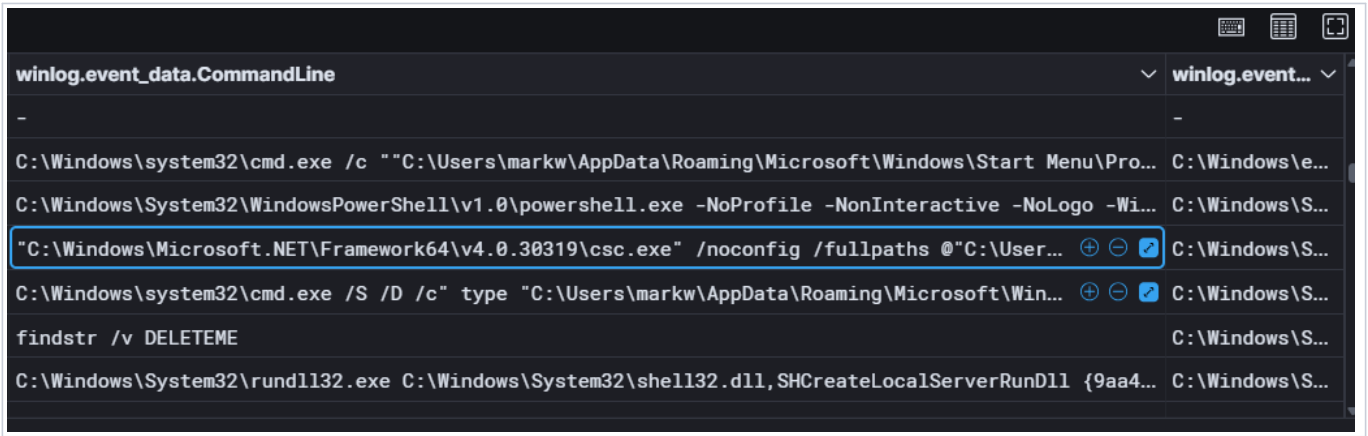


Figure 40. Other command-line activity under the markw profile seen alongside the collection activity.

Phase 12 - Webmail Access From Support01

The attacker also reached the mail system. Event ID 4624 on Support01 shows successful network logons (type 3) with the markw account from 10.10.11.156, which is DC01, starting at 22:39. The domain administrator reused the same credentials for Active Directory and for the mailbox, so the stolen password opened both. Network connection events then show web traffic from the host around 22:42, and process creation shows chrome.exe running. At 22:44:57 file creation events show **Accounts_Updates_1524.csv** written to `C:\Users\markw\Downloads` with its Zone.Identifier stream, meaning it was downloaded through the browser from the compromised mailbox. Its name suggests account information and it was opened in Notepad shortly after.

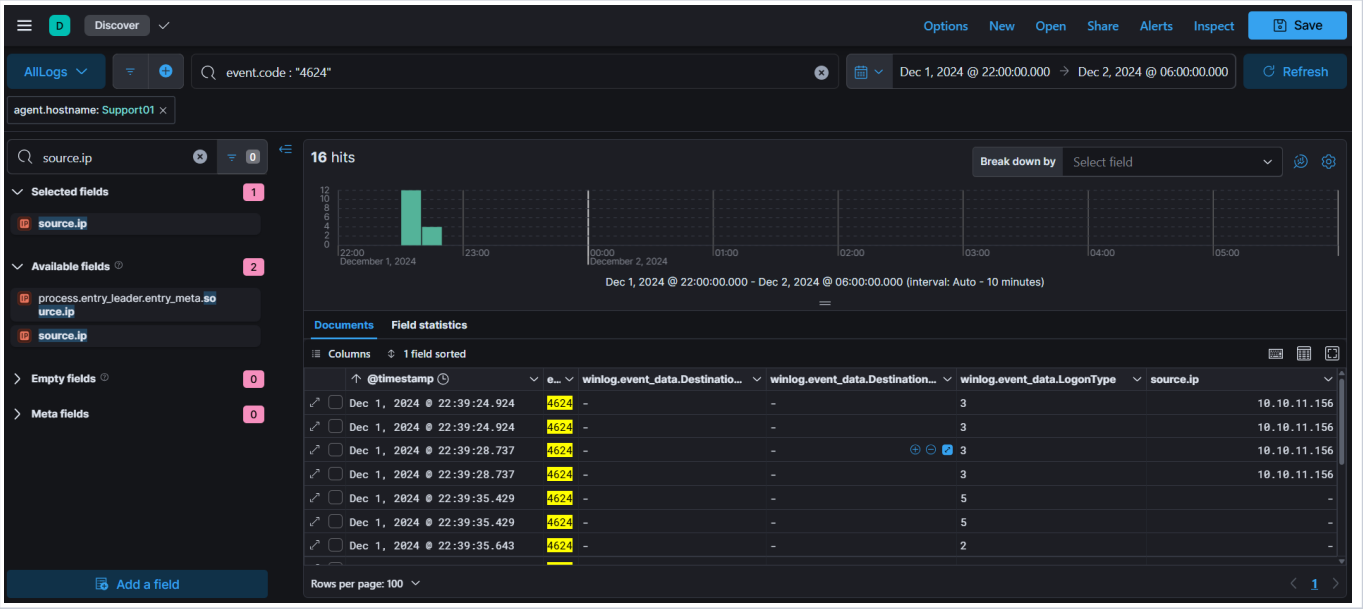


Figure 41. Network (type 3) logons on Support01 from 10.10.11.156 at 22:39.

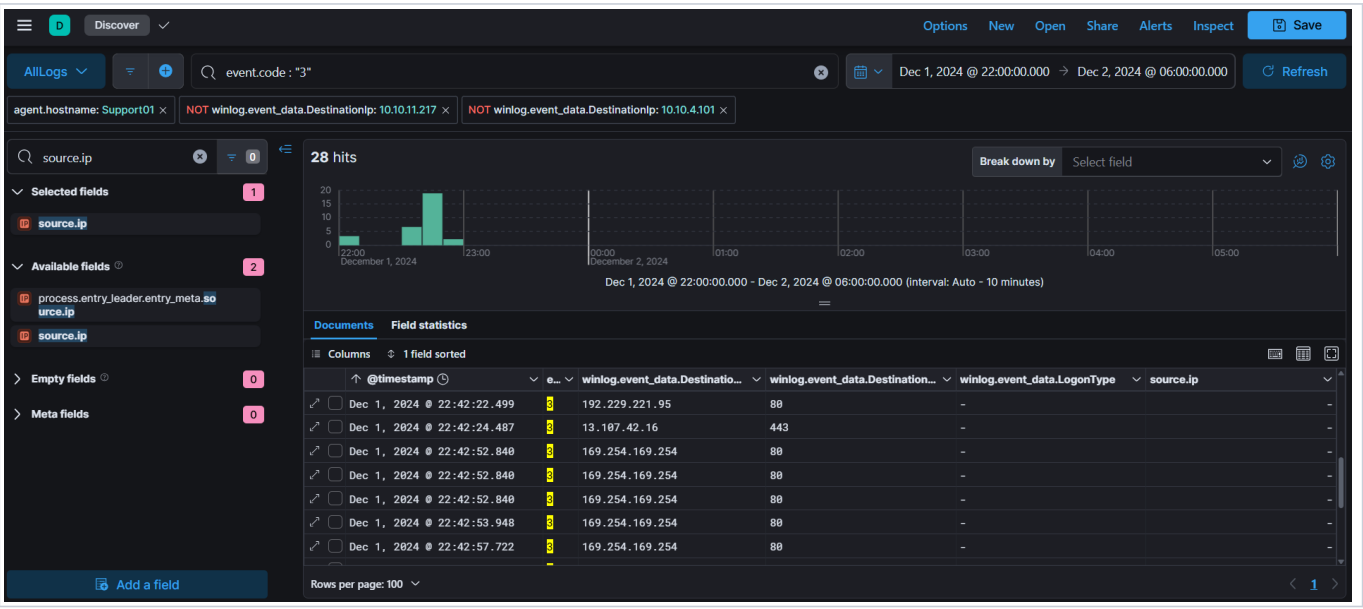


Figure 42. Outbound connections from Support01 around 22:42 (internal destinations filtered out).

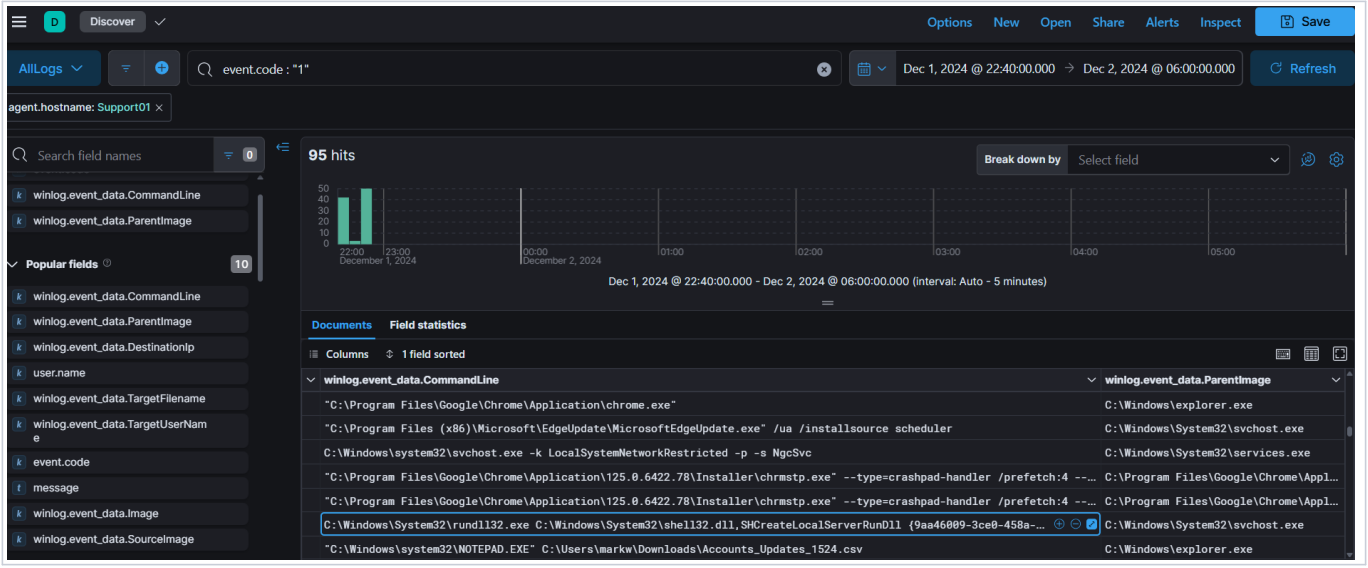


Figure 43. Support01 process creation: Chrome and Notepad opening Accounts_Updates_1524.csv from Downloads.

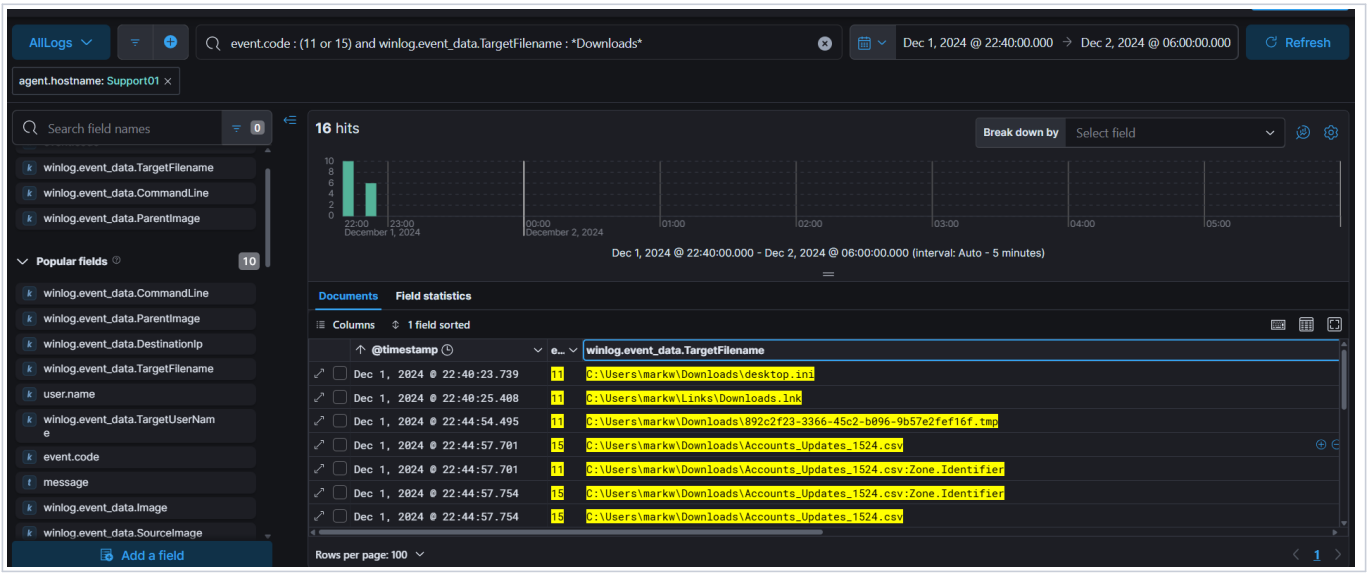


Figure 44. File creation in markw's Downloads folder: Accounts_Updates_1524.csv and its Zone.Identifier stream at 22:44:57.

Phase 13 - Command and Control Infrastructure

Finally I mapped where the beacons called home, using network connection events (Sysmon event ID 3) and Windows Filtering Platform events (5156 and 5158). Three different external servers appear, all on TCP port 443 so that the traffic blends in with normal HTTPS.

IT01, first beacon. rundll32.exe connects repeatedly to **3.68.97.124:443** at regular intervals, which is typical beaconing behavior.

IT01, injected process. ImagingDevices.exe (PID 9220) generates a large number of Windows Filtering Platform events, about 18,000. Nearly all (99.8%) go to **18.193.157.255:443**, a second server used by the injected code, and a small share goes to 10.10.11.156, DC01.

DC01. About 50,000 network connection events come from rundll32.exe, 99.8% of the sample, and nearly all go to **3.68.27.19:443**, starting at about 22:06 right after the service was installed. The remaining 0.2% belong to the chocolatey package manager contacting an internal address and are unrelated.

The addresses sit in cloud provider ranges, and using a different server for each host and stage adds redundancy for the attacker and makes blocking harder.

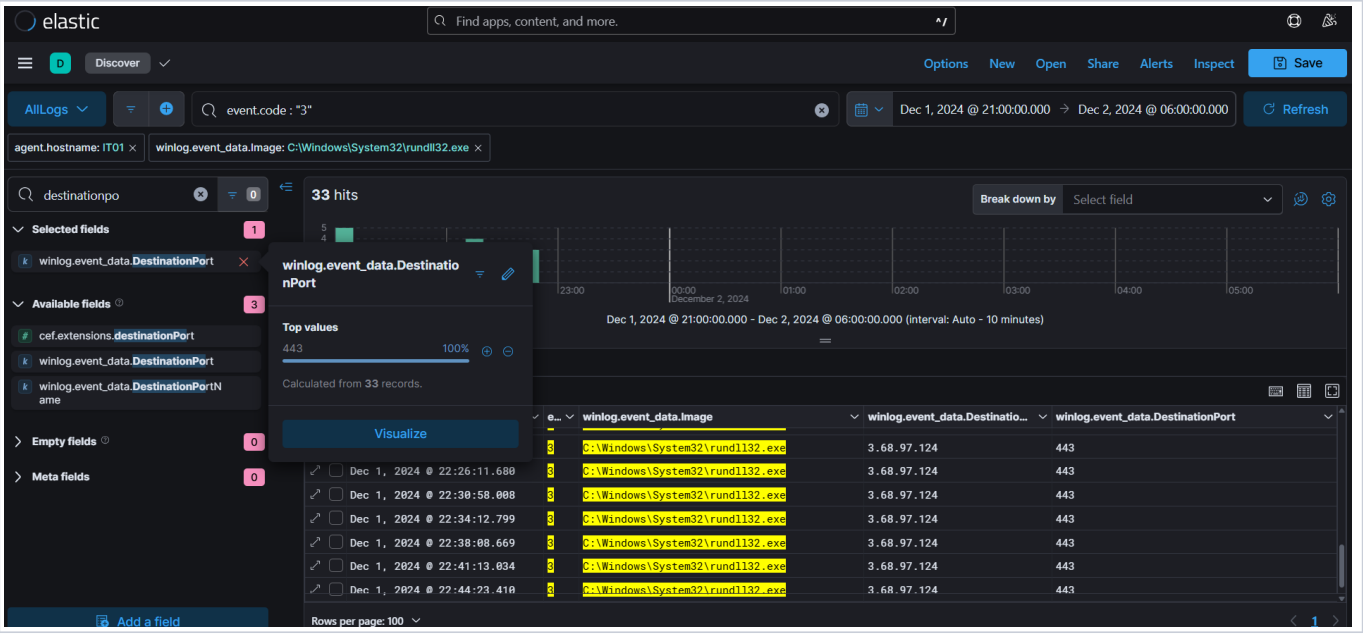


Figure 45. IT01: rundll32.exe connections to 3.68.97.124 on port 443.

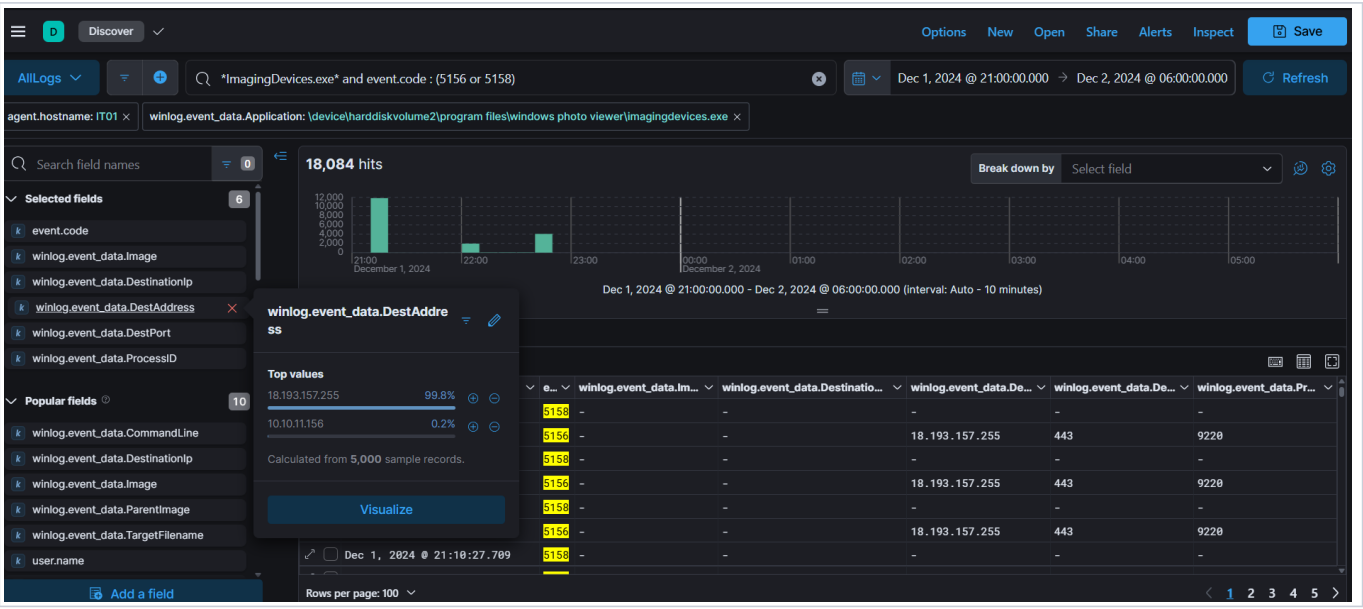


Figure 46. IT01: Filtering Platform events for ImagingDevices.exe, destination 18.193.157.255 on port 443.

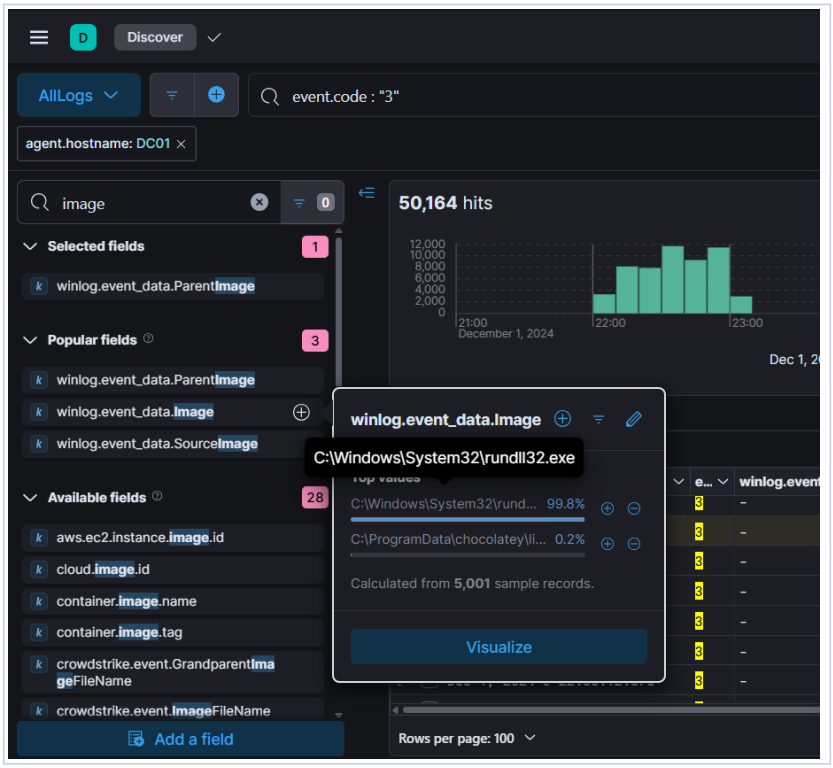


Figure 47. DC01 network connections by process image: rundll32.exe accounts for 99.8% of the sample.

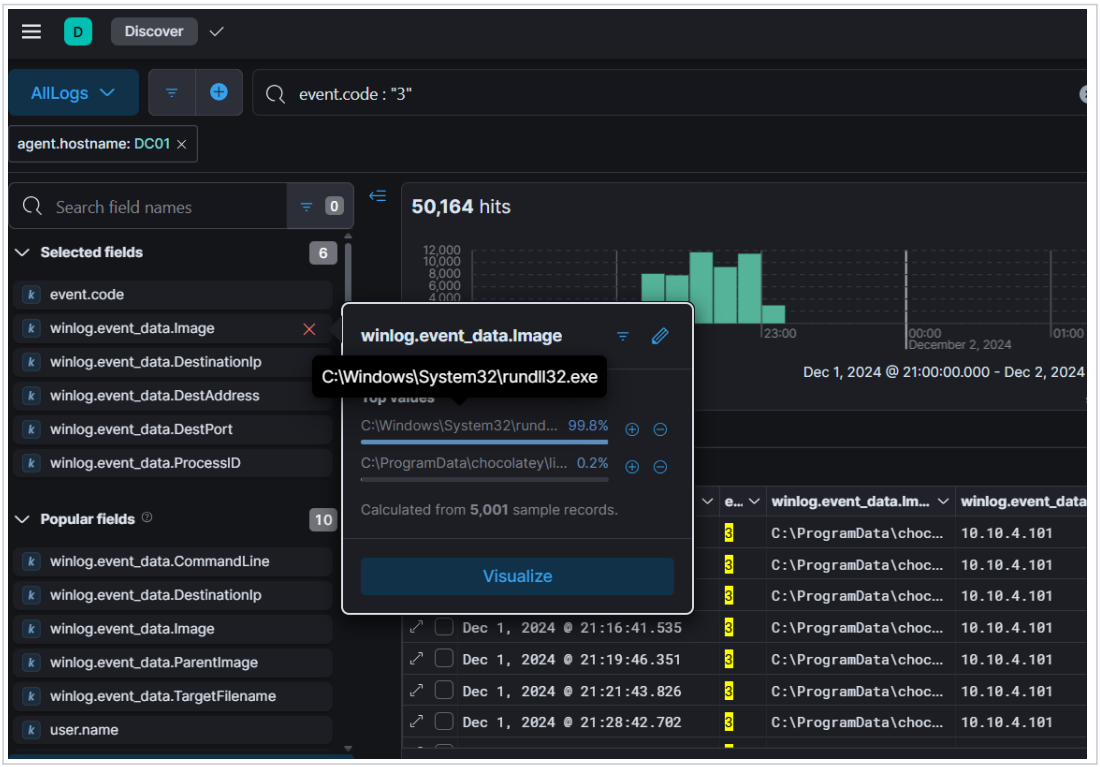


Figure 48. DC01 events by image, including the unrelated chocolatey connections to an internal address.

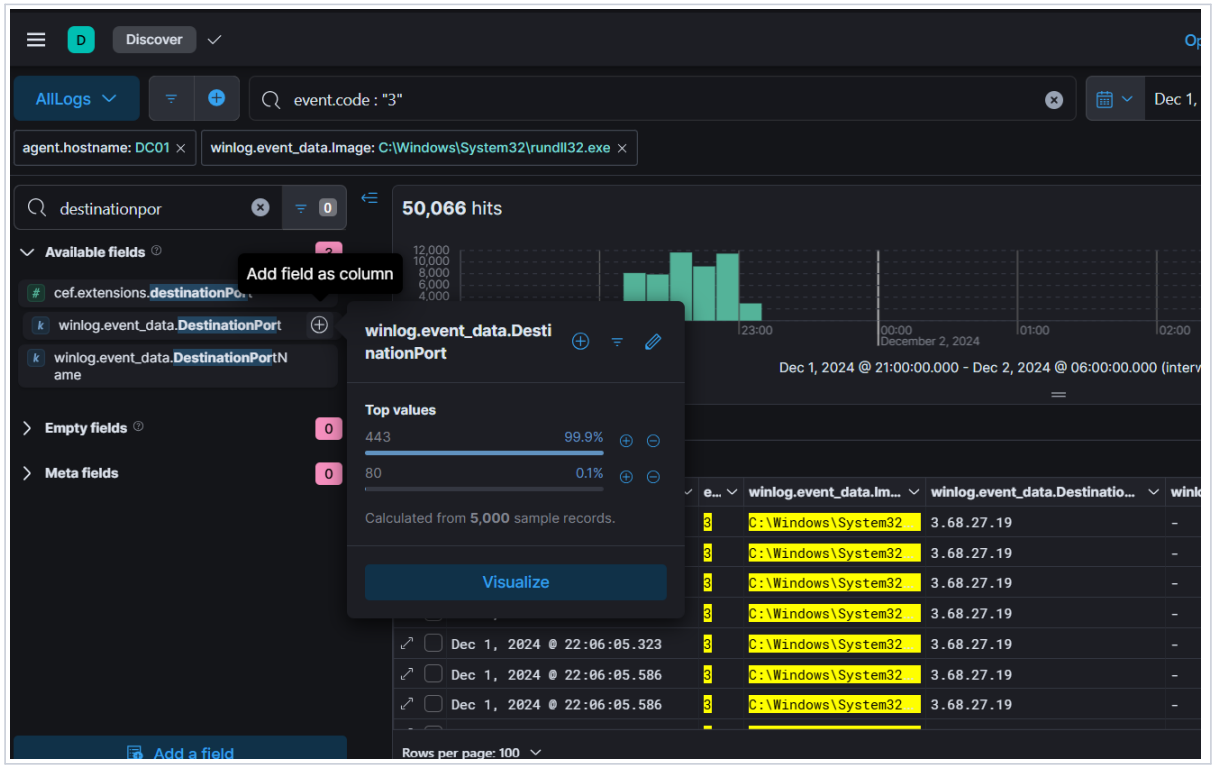


Figure 49. DC01 rundll32.exe connections: destination port 443 in 99.9% of the sample.

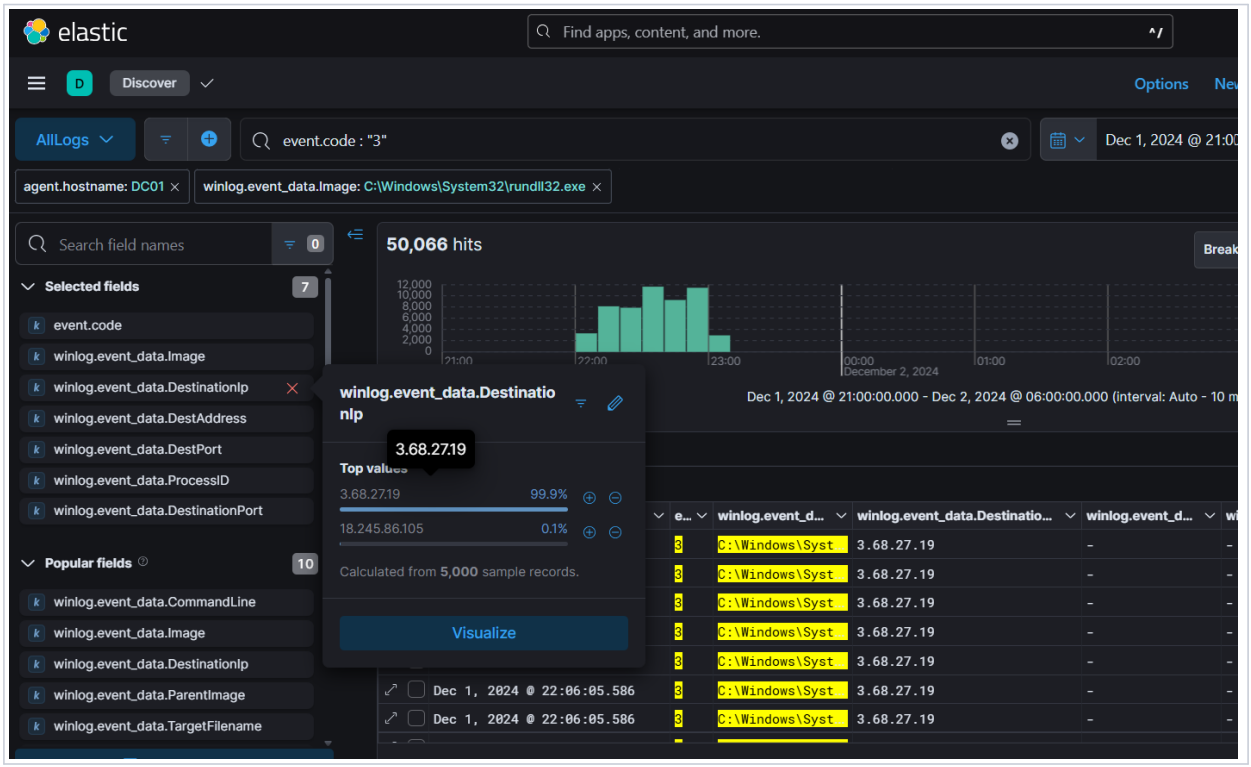


Figure 50. DC01 rundll32.exe connections: destination address 3.68.27.19 in 99.9% of the sample.

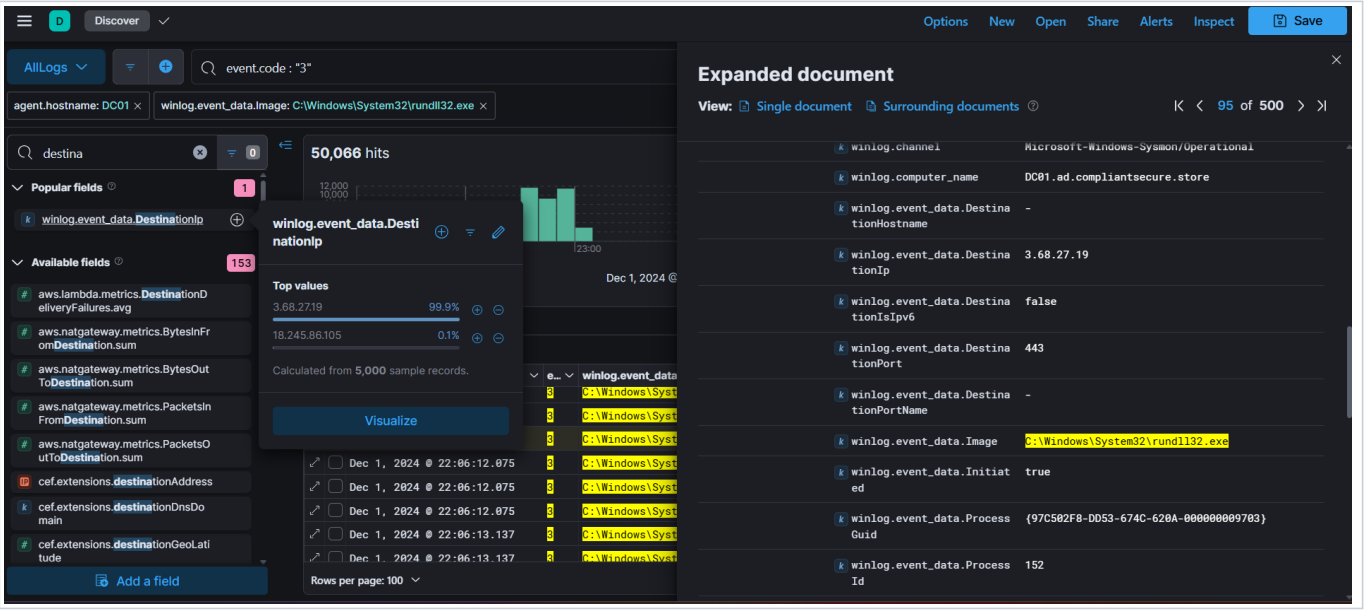


Figure 51. Expanded network connection event on DC01: rundll32.exe to 3.68.27.19 on port 443.

Phase 14 - Ransomware Deployment From a Network Share

The last phase is the ransomware. Searching process creation events whose image path starts with a double backslash, which means a network location, shows **\\10.10.11.18\Shares\patch.exe** started from explorer.exe on DC01 at 22:50:55 as the user AD\sql_admin, the account the attacker created. The share is on FILESERVER01, and the same file ran on several hosts, including DC01 and Support01. Placing one payload in a central share lets the attacker run it everywhere without copying it to each machine.

The expanded event provides the file hashes. Searching the SHA256 on VirusTotal gives the popular threat label *ransomware.conti/mint*, the categories ransomware, trojan and virus and the family labels conti, mint and zard, with detections such as Ransom:Win32/Conti. The malware is therefore a member of the Conti ransomware family, a ransomware-as-a-service operation known for double extortion. On IT01, a search for the term *patch* shows C:\ProgramData\patch.exe created at 22:48:07 by ImagingDevices.exe and then writing **R3ADM3.txt** into several folders (C:\Users\Public, DefaultAppPool, Default and C:\PerfLogs) at 22:49:29. The same file name in every folder is the ransom note.

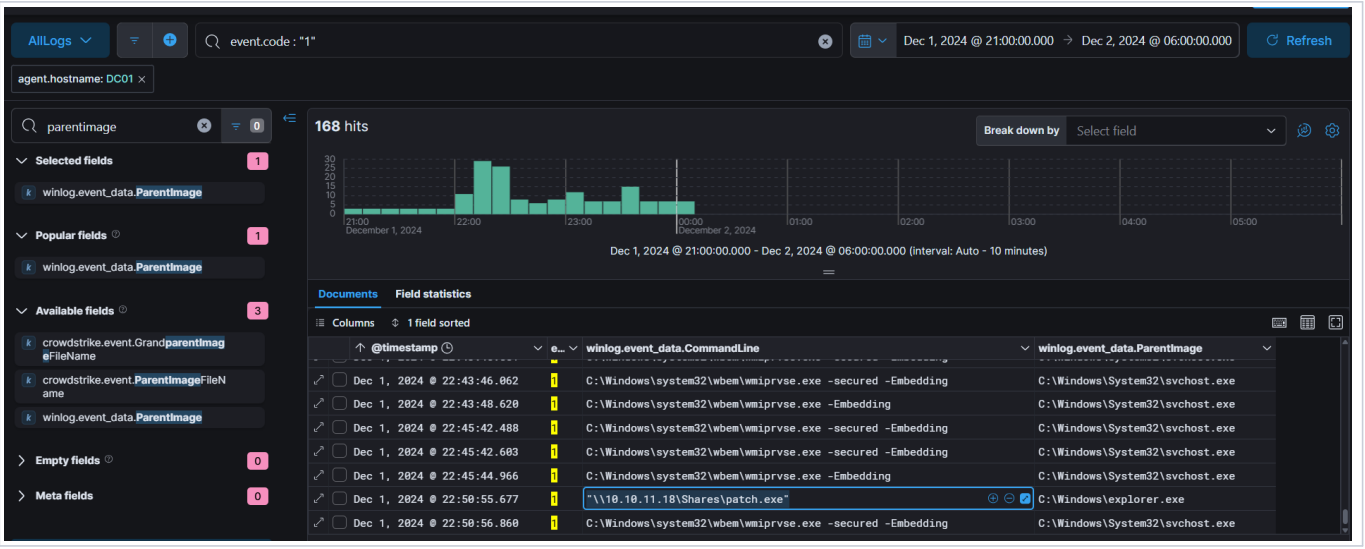


Figure 52. Process creation on DC01: \\10.10.11.18\Shares\patch.exe executed from explorer.exe at 22:50:55.

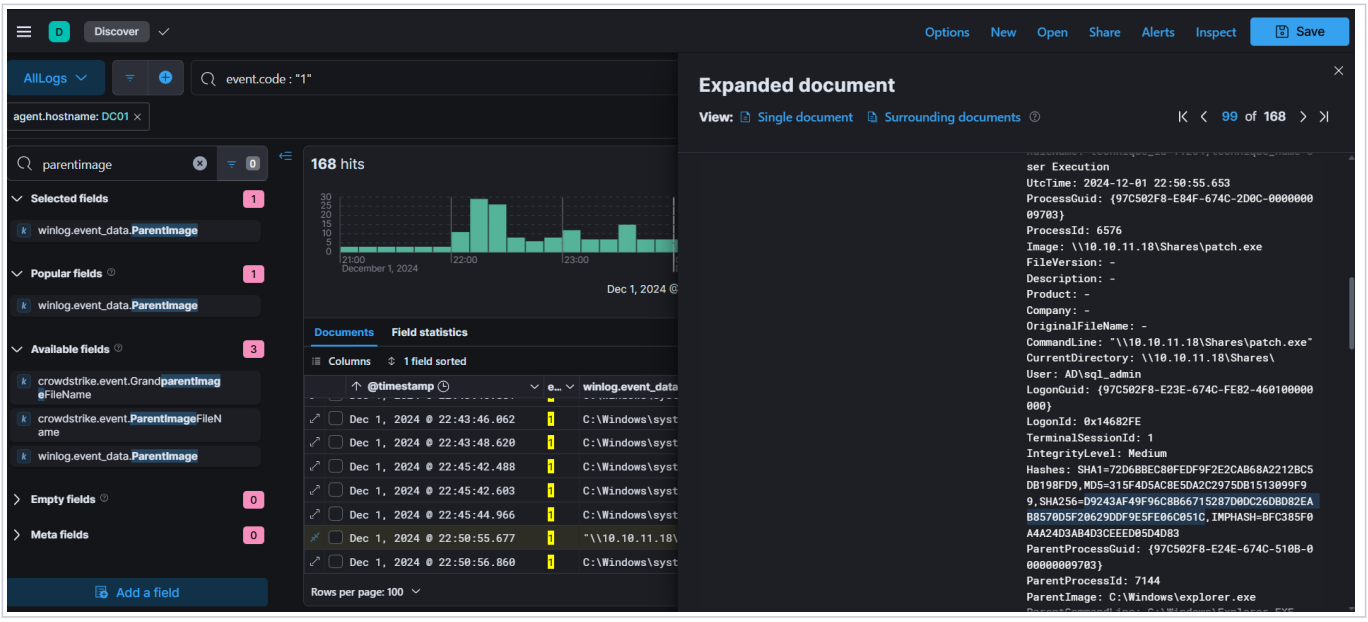


Figure 53. Expanded patch.exe event: run as AD\sql_admin from the share, with its hashes (SHA256 highlighted).

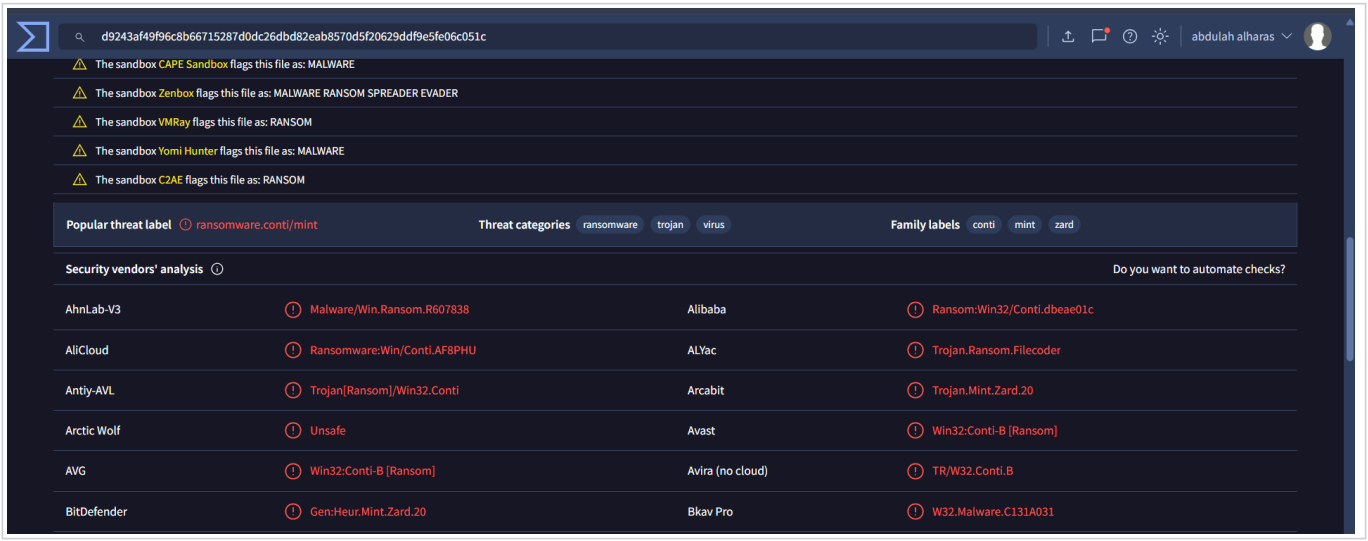


Figure 54. VirusTotal result for the patch.exe hash: ransomware.conti/mint with family labels conti, mint and zard.

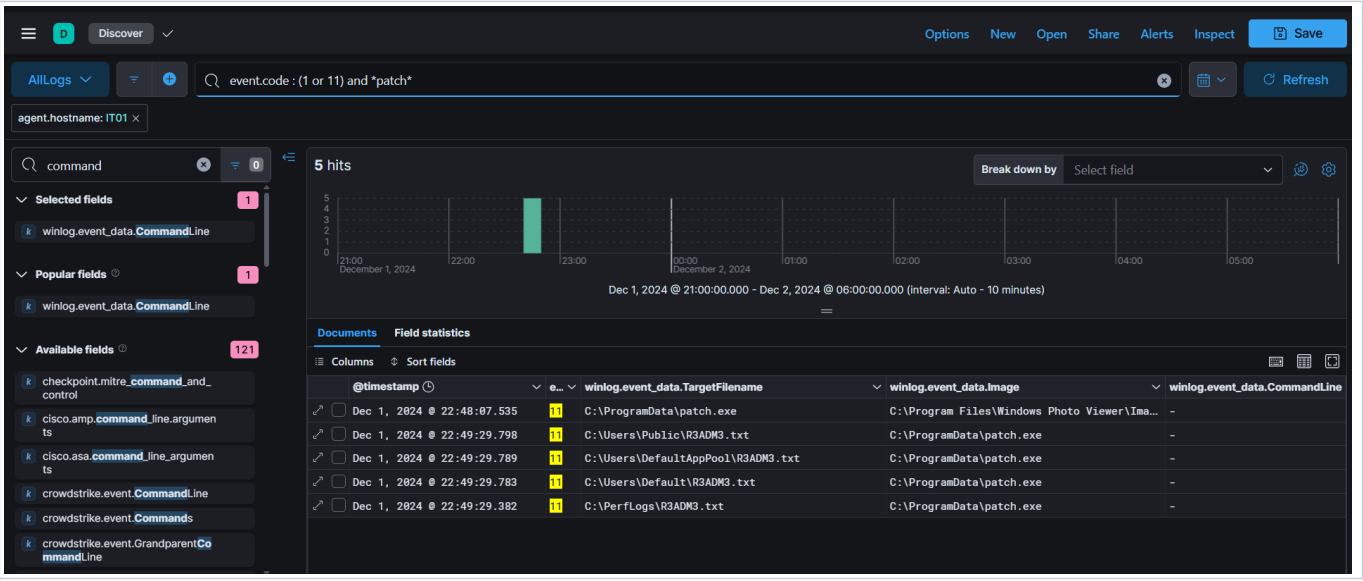


Figure 55. File creation events on IT01: patch.exe dropped by ImagingDevices.exe, then R3ADM3.txt written in several folders.

5. Attack Timeline

Time (2024-12-01, UTC)	Event
20:38	SMTP connections to MAIL01 from the spoofed-sender service emkei.cz (114.29.236.247)
21:02:00	chrome.exe creates NovaSecure_Audit_Findings.iso in the Administrator Downloads folder on IT01
21:02:17	7-Zip extracts the ISO (Compliance_Reports.lnk, 23.dll and decoy documents)
21:02:57	rundll32.exe runs 23.dll (StartW) launched from explorer.exe
21:09:27	CreateRemoteThread: rundll32.exe injects into ImagingDevices.exe
21:10 - 21:12	Discovery: ipconfig, arp, nbtstat, ping and nltest /domain_trusts
21:15:03	ProcDump dumps LSASS to C:\ProgramData\doc1.dmp
21:16 - 21:17	Dump archived with 7zr.exe, then doc1.7z and doc1.dmp deleted
22:03:41	markw credentials used over SMB; C:\Windows\0453497.exe created on DC01
22:04:02	Service 0453497 installed on DC01 (image path on ADMIN$)
22:06	Beacon on DC01 begins connecting to 3.68.27.19:443
22:07:21 - 22:07:54	1.7z extracted; sql_admin created and added to Administrators
22:12:12	RDP logon to DC01 as markw from EC2AMAZ-NVLPEI1
22:17:19	AnyDesk service installed on DC01
22:25:02	First interactive logon of sql_admin on DC01
22:27	1.bat reachability script with pings to the key systems
22:29:46	Admin_Passwords_v3_HASHED.csv opened from the IT share
22:31:34	RDP logon to FILESERVER01 as markw
22:38	Shares.7z created from the collected documents
22:39:24	markw network logon to Support01
22:44:57	Accounts_Updates_1524.csv downloaded from the mailbox through Chrome
22:48 - 22:50	patch.exe dropped on IT01 and run from the file server share on DC01; R3ADM3.txt written

Times are taken from the log records and are in UTC.

6. MITRE ATT&CK Mapping

Technique	ID	Observed activity
Phishing	T1566	Email sent through a spoofed-sender service led to the ISO download
User Execution: Malicious File	T1204.002	User opened Compliance_Reports.lnk from the ISO
Subvert Trust Controls: Mark-of-the-Web Bypass	T1553.005	ISO container used to deliver the shortcut and DLL
System Binary Proxy Execution: Rundll32	T1218.011	23.dll (StartW) executed through rundll32.exe
Process Injection	T1055	rundll32.exe injected a thread into ImagingDevices.exe
Command and Scripting Interpreter: Windows Command Shell	T1059.003	cmd.exe used for discovery, archiving and account commands
System Network Configuration Discovery	T1016	ipconfig /all, arp -a, nbtstat -n
Domain Trust Discovery	T1482	nltest /domain_trusts
Remote System Discovery	T1018	1.bat with pings to IT01, DC01, Support01 and FileServer01
OS Credential Dumping: LSASS Memory	T1003.001	procdump64.exe dumping lsass.exe
Valid Accounts: Domain Accounts	T1078.002	markw domain administrator credentials reused
Remote Services: SMB/Windows Admin Shares	T1021.002	Beacon executable copied to ADMIN$ on DC01
Remote Services: Remote Desktop Protocol	T1021.001	RDP to DC01 and FILESERVER01 (logon type 10)
Create or Modify System Process: Windows Service	T1543.003	Service 0453497 and AnyDesk service
Create Account: Local Account	T1136.001	sql_admin created and added to Administrators
Remote Access Software	T1219	AnyDesk installed on DC01
Data from Network Shared Drive	T1039	IT share and Shares folder on FILESERVER01 accessed
Archive Collected Data: Archive via Utility	T1560.001	doc1.7z and Shares.7z created with 7-Zip
Indicator Removal: File Deletion	T1070.004	doc1.7z and doc1.dmp deleted after archiving
Ingress Tool Transfer	T1105	procdump64.exe, 7zr.exe, AdFind.exe and AnyDesk.exe dropped
Application Layer Protocol: Web Protocols	T1071.001	C2 over TCP 443 to three external servers
Data Encrypted for Impact	T1486	Conti ransomware patch.exe and R3ADM3.txt notes

7. Indicators of Compromise

Type	Value	Notes
Domain	`emkei.cz`	Spoofed-sender mail service seen in the MAIL01 logs
IP address	`114.29.236.247`	Address of emkei.cz connecting to MAIL01
IP address	`3.68.97.124:443`	C2 contacted by rundll32.exe on IT01
IP address	`18.193.157.255:443`	C2 contacted by ImagingDevices.exe on IT01
IP address	`3.68.27.19:443`	C2 contacted by rundll32.exe on DC01
File name	`NovaSecure_Audit_Findings.iso`	Malicious ISO delivered through webmail
SHA256	`F445F806066028D621D8E6A6B949E59342C309DFEB1D517BD847F70069B1B8DD`	Hash of the ISO
File names	`Compliance_Reports.lnk, 23.dll`	Shortcut and loader DLL (export StartW) from the ISO
Process	`C:\Program Files\Windows Photo Viewer\ImagingDevices.exe`	Legitimate binary used as injection target
File path	`C:\ProgramData\procdump64.exe`	Credential dumping tool
File path	`C:\ProgramData\7zr.exe`	Standalone 7-Zip utility
File paths	`C:\ProgramData\doc1.dmp, doc1.7z`	LSASS dump and its archive (deleted)
File path	`C:\Windows\0453497.exe`	Service beacon on DC01 (service 0453497)
File paths	`C:\ProgramData\1.7z, AdFind.exe, AnyDesk.exe`	Archive and tools dropped on DC01
File path	`C:\Users\sql_admin\Desktop\1.bat`	Reachability script
Accounts	`sql_admin, markw (compromised)`	Rogue administrator account; compromised domain administrator
Host name	`EC2AMAZ-NVLPEI1`	Attacker workstation seen in 4776 events
File name	`Shares.7z`	Archive of collected shared documents
File path	`\\10.10.11.18\Shares\patch.exe`	Conti ransomware payload run from the share
SHA256	`D9243AF49F96C8B66715287D0DC26DBD82EAB8570D5F20629DDF9E5FE06C051C`	Hash of patch.exe
File name	`R3ADM3.txt`	Ransom note dropped in multiple folders

8. Impact Assessment

The attacker obtained domain administrator credentials, ran code with SYSTEM privileges on the domain controller, created a rogue administrator account and installed a second remote access channel. Documents from the file server were staged in an archive for exfiltration, a file named like an administrator password list was opened and the mailbox of the compromised account was accessed. Ransomware was then run from a network share on several hosts, including the domain controller. Credentials, mailbox content and shared documents must be considered exposed, and every system in the domain must be treated as untrusted until rebuilt.

9. Recommendations

- Isolate the affected hosts, block the three C2 addresses and emkei.cz at the network and mail gateways, and keep the evidence.
- Remove the service 0453497 and the AnyDesk service, delete the sql_admin account and review every other account, service and remote access tool on all hosts.
- Rebuild or restore the domain controller and the other affected systems from a known good state, then reset all administrator, service and mailbox credentials, including the KRBTGT account twice.
- Enforce a strong password policy and multi-factor authentication for administrators and webmail, and stop reusing the same password across Active Directory and the mail system.
- Block or warn on ISO, IMG and LNK attachments and downloads from webmail, and disable automatic mounting of disk images for standard users.
- Protect LSASS (Credential Guard or RunAsPPL), restrict administrator logons to workstations and alert on process access to lsass.exe.
- Move sensitive files such as password lists out of shared folders and restrict write access to shares that can host executables.
- Add detections for rundll32.exe loading DLLs from user folders, CreateRemoteThread into signed Windows binaries, new services whose image path is on ADMIN$, user and group changes on the domain controller, AnyDesk installation, executables launched from UNC paths and repeated outbound connections on port 443 to rare destinations.

10. Conclusion

The logs prove that CompliantSecure was compromised by a phishing-driven Bumblebee intrusion attributed to Gold Cabin. The attacker went from a spoofed email to a malicious ISO, a beacon injected into a legitimate process, stolen domain administrator credentials, control of the domain controller with several persistence mechanisms, collection of sensitive documents and Conti ransomware, all in roughly two hours. Rebuilding the affected systems, rotating credentials and deploying the detections listed above are needed to remediate the incident and to catch similar activity earlier in the future.